



2024/2690

18.10.2024

DURCHFÜHRUNGSVERORDNUNG (EU) 2024/2690 DER KOMMISSION

vom 17. Oktober 2024

mit Durchführungsbestimmungen zur Richtlinie (EU) 2022/2555 im Hinblick auf die technischen und methodischen Anforderungen der Risikomanagementmaßnahmen im Bereich der Cybersicherheit und die Präzisierung der Fälle, in denen ein Sicherheitsvorfall in Bezug auf DNS-Diensteanbieter, TLD-Namenregister, Anbieter von Cloud-Computing-Diensten, Anbieter von Rechenzentrumsdiensten, Betreiber von Inhaltzustellnetzen, Anbieter verwalteter Dienste, Anbieter verwalteter Sicherheitsdienste, Anbieter von Online-Marktplätzen, Online-Suchmaschinen und Plattformen für Dienste sozialer Netzwerke und Vertrauensdiensteanbieter als erheblich gilt

(Text von Bedeutung für den EWR)

DIE EUROPÄISCHE KOMMISSION —

gestützt auf den Vertrag über die Arbeitsweise der Europäischen Union,

gestützt auf die Richtlinie (EU) 2022/2555 des Europäischen Parlaments und des Rates vom 14. Dezember 2022 über Maßnahmen für ein hohes gemeinsames Cybersicherheitsniveau in der Union, zur Änderung der Verordnung (EU) Nr. 910/2014 und der Richtlinie (EU) 2018/1772 sowie zur Aufhebung der Richtlinie (EU) 2016/1148 (NIS-2-Richtlinie) ⁽¹⁾, insbesondere auf Artikel 21 Absatz 5 Unterabsatz 1 und Artikel 23 Absatz 11 Unterabsatz 2,

in Erwägung nachstehender Gründe:

- (1) In dieser Verordnung werden in Bezug auf die von Artikel 3 der Richtlinie (EU) 2022/2555 erfassten DNS-Diensteanbieter, TLD-Namenregister, Anbieter von Cloud-Computing-Diensten, Anbieter von Rechenzentrumsdiensten, Betreiber von Inhaltzustellnetzen, Anbieter verwalteter Dienste, Anbieter verwalteter Sicherheitsdienste, Anbieter von Online-Marktplätzen, Online-Suchmaschinen und Plattformen für Dienste sozialer Netzwerke und Vertrauensdiensteanbieter (im Folgenden „betreffende Einrichtungen“) die technischen und methodischen Anforderungen der in Artikel 21 Absatz 2 der Richtlinie (EU) 2022/2555 genannten Maßnahmen festgelegt und die Fälle präzisiert, in denen ein Sicherheitsvorfall gemäß Artikel 23 Absatz 3 der Richtlinie (EU) 2022/2555 als erheblich anzusehen ist.
- (2) Angesichts des grenzüberschreitenden Charakters ihrer Tätigkeiten und zur Gewährleistung eines kohärenten Rahmens für Vertrauensdiensteanbieter sollte in dieser Verordnung in Bezug auf Vertrauensdiensteanbieter neben der Festlegung der technischen und methodischen Anforderungen der Risikomanagementmaßnahmen im Bereich der Cybersicherheit ebenfalls präzisiert werden, in welchen Fällen ein Sicherheitsvorfall als erheblich anzusehen ist.
- (3) Nach Artikel 21 Absatz 5 Unterabsatz 3 der Richtlinie (EU) 2022/2555 beruhen die technischen und methodischen Anforderungen der im Anhang dieser Verordnung festgelegten Risikomanagementmaßnahmen im Bereich der Cybersicherheit auf europäischen und internationalen Normen wie ISO/IEC 27001, ISO/IEC 27002 und ETSI EN 319401 sowie auf technischen Spezifikationen wie CEN/TS 18026:2024, die für die Sicherheit von Netz- und Informationssystemen von Belang sind.
- (4) Bezüglich der Umsetzung und Anwendung der technischen und methodischen Anforderungen der im Anhang dieser Verordnung festgelegten Risikomanagementmaßnahmen im Bereich der Cybersicherheit sollten — im Einklang mit dem Grundsatz der Verhältnismäßigkeit — die unterschiedlichen Risikoexpositionen der betreffenden Einrichtungen wie Kritikalität der betreffenden Einrichtung, Risiken, denen sie ausgesetzt sind, Größe und Struktur der betreffenden Einrichtung sowie Wahrscheinlichkeit des Eintretens von Sicherheitsvorfällen und deren Schwere, einschließlich ihrer gesellschaftlichen und wirtschaftlichen Auswirkungen, bei der Einhaltung der im Anhang dieser Verordnung festgelegten technischen und methodischen Anforderungen der Risikomanagementmaßnahmen im Bereich der Cybersicherheit gebührend berücksichtigt werden.

⁽¹⁾ ABl. L 333 vom 27.12.2022, S. 80, ELI: <http://data.europa.eu/eli/dir/2022/2555/oj>.

- (5) Können die betreffenden Einrichtungen einige der technischen und methodischen Anforderungen der Risikomanagementmaßnahmen im Bereich der Cybersicherheit wegen ihrer Größe nicht umsetzen, so sollten sie — im Einklang mit dem Grundsatz der Verhältnismäßigkeit — die Möglichkeit haben, andere Ausgleichsmaßnahmen zu ergreifen, die geeignet sind, den Zweck dieser Anforderungen zu erreichen. Bei der Festlegung der Rollen, Verantwortlichkeiten und Weisungsbefugnisse in Bezug auf die Sicherheit der Netz- und Informationssysteme innerhalb der betreffenden Einrichtung könnte es für Kleinstunternehmen schwierig sein, widerstrebende Pflichten und sich widersprechende Verantwortlichkeitsbereiche zu trennen. Solche Einrichtungen sollten Ausgleichsmaßnahmen wie eine gezielte Beaufsichtigung durch ihr Management oder eine verstärkte Überwachung und Protokollierung in Betracht ziehen können.
- (6) Bestimmte technische und methodische Anforderungen, die im Anhang dieser Verordnung festgelegt sind, sollten von den betreffenden Einrichtungen angewandt werden, soweit dies angemessen, anwendbar oder durchführbar ist. Hält es eine betreffende Einrichtung es für nicht angemessen, nicht anwendbar oder nicht durchführbar, bestimmte technische und methodische Anforderungen, die im Anhang dieser Verordnung festgelegt sind, anzuwenden, sollte sie ihre diesbezügliche Begründung in verständlicher Weise dokumentieren. Die zuständigen nationalen Behörden können bei der Beaufsichtigung eine angemessene Frist berücksichtigen, die betreffenden Einrichtungen benötigen, um die technischen und methodischen Anforderungen der Risikomanagementmaßnahmen im Bereich der Cybersicherheit umzusetzen.
- (7) Die ENISA oder die gemäß der Richtlinie (EU) 2022/2555 zuständigen nationalen Behörden können die betreffenden Einrichtungen bei der Ermittlung, Analyse und Bewertung von Risiken zwecks Umsetzung der technischen und methodischen Anforderungen an die Einrichtung und Aufrechterhaltung eines geeigneten Risikomanagementrahmens anleitend unterstützen. Eine solche Anleitung kann sich insbesondere auf nationale und sektorale Risikobewertungen sowie spezifische Risikobewertungen für eine bestimmte Art von Einrichtung beziehen. Die Anleitung kann auch Instrumente oder Vorlagen für die Entwicklung eines Risikomanagementrahmens auf der Ebene der betreffenden Einrichtungen umfassen. Die betreffenden Einrichtungen können auch mit Rahmen, Anleitungen oder anderen Mechanismen, die im nationalen Recht der Mitgliedstaaten vorgesehen sind, sowie mit einschlägigen europäischen und internationalen Normen beim Nachweis der Einhaltung dieser Durchführungsverordnung unterstützt werden. Darüber hinaus können die ENISA oder die gemäß der Richtlinie (EU) 2022/2555 zuständigen nationalen Behörden die betreffenden Einrichtungen dabei unterstützen, geeignete Lösungen für den Umgang mit den bei solchen Risikobewertungen ermittelten Risiken zu finden und umzusetzen. Eine solche Anleitung sollte die Pflicht der betreffenden Einrichtungen, die bestehenden Risiken für die Sicherheit von Netz- und Informationssystemen zu ermitteln und zu dokumentieren, sowie die Pflicht der betreffenden Einrichtungen, die technischen und methodischen Anforderungen der im Anhang dieser Verordnung festgelegten Risikomanagementmaßnahmen im Bereich der Cybersicherheit entsprechend ihren Bedürfnissen und Ressourcen umzusetzen, unberührt lassen.
- (8) Netzsicherheitsmaßnahmen in Bezug auf i) den Übergang zur neuesten Generation der Kommunikationsprotokolle für die Netzwerkschicht, ii) die Einführung international vereinbarter und interoperabler moderner E-Mail-Kommunikationsnormen und iii) die Anwendung der bewährten Verfahren für die DNS-Sicherheit wie auch die Sicherheit und Hygiene des Internet-Routings bringen besondere Herausforderungen hinsichtlich der Ermittlung der jeweils besten bestehenden Normen und Einführungstechniken mit sich. Um so bald wie möglich ein hohes gemeinsames Cybersicherheitsniveau in allen Netzen zu erreichen, sollte die Kommission mit Unterstützung der Agentur der Europäischen Union für Cybersicherheit (ENISA) und in Zusammenarbeit mit den zuständigen Behörden, mit der Wirtschaft — einschließlich der Telekommunikationsbranche — und anderen Interessenträgern die Entwicklung eines Multi-Stakeholder-Forums unterstützen, dessen Aufgabe es wäre, diese besten bestehenden Normen und Einführungstechniken zu ermitteln. Die Pflicht der betreffenden Einrichtungen zur Umsetzung der technischen und methodischen Anforderungen der im Anhang dieser Verordnung festgelegten Risikomanagementmaßnahmen im Bereich der Cybersicherheit sollte von solchen Empfehlungen des Multi-Stakeholder-Forums jedoch unberührt bleiben.
- (9) Gemäß Artikel 21 Absatz 2 Buchstabe a der Richtlinie (EU) 2022/2555 sollten wesentliche und wichtige Einrichtungen nicht nur über Konzepte für die Risikoanalyse, sondern auch über Konzepte für die Sicherheit der Informationssysteme verfügen. Zu diesem Zweck sollten die betreffenden Einrichtungen ein Konzept für die Sicherheit von Netz- und Informationssystemen sowie themenspezifische Konzepte, wie z. B. für die Zugangs- bzw. Zugriffskontrolle, festlegen, die mit dem Konzept für die Sicherheit von Netz- und Informationssystemen vereinbar sein sollten. Das Konzept für die Sicherheit von Netz- und Informationssystemen sollte die übergeordnete allgemeine Unterlage sein, in der der Gesamtansatz der betreffenden Einrichtungen für die Sicherheit ihrer Netz- und Informationssysteme dargelegt wird, und sollte von den Leitungsorganen der betreffenden Einrichtungen genehmigt werden. Die themenspezifischen Konzepte sollten von einer geeigneten Leitungsebene genehmigt werden. In dem Konzept sollten Indikatoren und Maßnahmen zur Überwachung seiner Umsetzung und des aktuellen Reifegrads der Netz- und Informationssicherheit in den betreffenden Einrichtungen festgelegt werden, um insbesondere die Beaufsichtigung der Umsetzung der Risikomanagementmaßnahmen im Bereich der Cybersicherheit durch die Leitungsorgane zu erleichtern.

- (10) Für die Zwecke der technischen und methodischen Anforderungen im Anhang dieser Verordnung sollte der Begriff „Nutzer“ alle juristischen und natürlichen Personen erfassen, die Zugang zu den Netz- und Informationssystemen der Einrichtung haben.
- (11) Um die bestehenden Risiken für die Sicherheit von Netz- und Informationssystemen zu ermitteln und anzugehen, sollten die betreffenden Einrichtungen einen geeigneten Risikomanagementrahmen einführen und aufrechterhalten. Als Teil dieses Risikomanagementrahmens sollten die betreffenden Einrichtungen einen Risikobehandlungsplan aufstellen, umsetzen und überwachen. Die betreffenden Einrichtungen können den Risikobehandlungsplan zur Bestimmung und Priorisierung von Optionen und Maßnahmen für die Behandlung von Risiken benutzen. Zu den Risikobehandlungsoptionen gehören insbesondere die Vermeidung, die Verringerung oder — in Ausnahmefällen — das Akzeptieren des Risikos. Die gewählten Risikobehandlungsoptionen sollten den Ergebnissen der von der betreffenden Einrichtung durchgeführten Risikobewertung entsprechen und mit dem Konzept der betreffenden Einrichtung für die Sicherheit von Netz- und Informationssystemen im Einklang stehen. Um den gewählten Risikobehandlungsoptionen Wirkung zu verleihen, sollten die betreffenden Einrichtungen geeignete Risikobehandlungsmaßnahmen ergreifen.
- (12) Um Ereignisse, Beinahe-Vorfälle und Sicherheitsvorfälle zu erkennen, sollten die betreffenden Einrichtungen ihre Netz- und Informationssysteme überwachen und Maßnahmen zur Bewertung von Ereignissen, Beinahe-Vorfällen und Sicherheitsvorfällen treffen. Solche Maßnahmen sollten es ermöglichen, netzgestützte Angriffe auf der Grundlage anomaler Muster des eingehenden oder ausgehenden Verkehrs sowie Denial-of-Service-Angriffe zeitnah zu erkennen.
- (13) Die betreffenden Einrichtungen werden dazu ermuntert, im Zuge der Durchführung einer Analyse der betrieblichen Auswirkungen (BIA) auch eine umfassende Analyse vorzunehmen, in der sie — soweit angemessen — maximal tolerierbare Ausfallzeiten, Vorgaben für Wiederherstellungszeiten und Wiederherstellungspunkte und Zielvorgaben für die Erbringung der Dienste erfassen.
- (14) Zur Minderung der Risiken, die sich aus der Lieferkette einer betreffenden Einrichtung und ihren Beziehungen zu ihren Anbietern bzw. Lieferanten ergeben, sollten die betreffenden Einrichtungen ein Konzept für die Sicherheit der Lieferkette festlegen, das ihre Beziehungen zu ihren direkten Anbietern und Diensteanbietern regelt. Diese Einrichtungen sollten in die Verträge mit ihren direkten Anbietern oder Diensteanbietern angemessene Sicherheitsklauseln aufnehmen, in denen sie beispielsweise — soweit angemessen — Risikomanagementmaßnahmen im Bereich der Cybersicherheit gemäß Artikel 21 Absatz 2 der Richtlinie (EU) 2022/2555 oder anderer ähnlicher rechtlicher Anforderungen festlegen.
- (15) Die betreffenden Einrichtungen sollten regelmäßig Sicherheitstests auf der Grundlage spezieller Konzepte und Verfahren durchführen, um zu überprüfen, ob die Risikomanagementmaßnahmen im Bereich der Cybersicherheit umgesetzt wurden und ordnungsgemäß funktionieren. Sicherheitstests können in bestimmten Netz- und Informationssystemen oder in der betreffenden Einrichtung in ihrer Gesamtheit durchgeführt werden und automatische oder manuelle Tests, Penetrationstests, eine Schwachstellensuche, statische und dynamische Prüfungen der Sicherheit von Anwendungen, Konfigurationstests oder Sicherheitsaudits umfassen. Die betreffenden Einrichtungen können Sicherheitstests in ihren Netz- und Informationssystemen bei deren Einrichtung, nach Aufrüstungen der Infrastruktur oder von Anwendungen oder nach Änderungen, die sie für erheblich halten, oder nach einer Wartung durchführen. Die Ergebnisse der Sicherheitstests sollten in die Konzepte und Verfahren der betreffenden Einrichtungen für die Bewertung der Wirksamkeit der Risikomanagementmaßnahmen im Bereich der Cybersicherheit sowie in unabhängige Überprüfungen ihrer Konzepte für die Sicherheit von Netz- und Informationssystemen einfließen.
- (16) Zur Vermeidung erheblicher Störungen und Schäden, die durch die Ausnutzung nicht behobener Schwachstellen in Netz- und Informationssystemen verursacht werden, sollten die betreffenden Einrichtungen geeignete Sicherheitspatch-Managementverfahren festlegen und anwenden, die mit den Änderungs-, Schwachstellen- und Risikomanagementverfahren sowie anderen einschlägigen Verfahren der betreffenden Einrichtungen im Einklang stehen. Die betreffenden Einrichtungen sollten Maßnahmen ergreifen, die in einem angemessenen Verhältnis zu ihrer Mittelausstattung stehen, um sicherzustellen, dass durch Sicherheitspatches keine zusätzlichen Schwachstellen oder Instabilitäten eingebracht werden. Im Falle einer geplanten Nichtverfügbarkeit des Dienstes, die durch die Anwendung von Sicherheitspatches verursacht wird, sollen die betreffenden Einrichtungen ihre Kunden im Voraus angemessen hierüber informieren.

- (17) Die betreffenden Einrichtungen sollten die Risiken managen, die sich aus dem Erwerb von IKT-Produkten oder -Dienstleistungen von Anbietern oder Diensteanbietern ergeben, und sich vergewissern, dass die zu erwerbenden IKT-Produkte oder -Dienstleistungen ein bestimmtes Schutzniveau in Bezug auf die Cybersicherheit erreichen, z. B. anhand europäischer Cybersicherheitszertifikate und EU-Konformitätserklärungen für IKT-Produkte oder -Dienstleistungen, die im Rahmen eines gemäß Artikel 49 der Verordnung (EU) 2019/881 des Europäischen Parlaments und des Rates⁽²⁾ angenommenen europäischen Systems für die Cybersicherheitszertifizierung ausgestellt wurden. Wenn die betreffenden Einrichtungen Sicherheitsanforderungen für die zu erwerbenden IKT-Produkte festlegen, sollten sie die grundlegenden Cybersicherheitsanforderungen berücksichtigen, die in der Verordnung des Europäischen Parlaments und des Rates über horizontale Cybersicherheitsanforderungen an Produkte mit digitalen Elementen festgelegt sind.
- (18) Zum Schutz vor Cyberbedrohungen und zur Unterstützung der Prävention und Eindämmung von Datenschutzverletzungen sollten die betreffenden Einrichtungen Netzsicherheitslösungen umsetzen. Typische Netzsicherheitslösungen wären der Einsatz von Firewalls zum Schutz der internen Netze der betreffenden Einrichtungen, die Beschränkung der Verbindungen und des Zugangs zu Diensten, soweit solche Verbindungen und Zugriffe unbedingt notwendig sind, aber auch die Verwendung virtueller privater Netze für den Fernzugriff und das Zulassen von Verbindungen von Diensteanbietern nur nach einem Genehmigungsantrag und für einen bestimmten Zeitraum, z. B. für die Dauer von Wartungsarbeiten.
- (19) Zum Schutz der Netze der betreffenden Einrichtungen und ihrer Informationssysteme vor Schadsoftware und nicht genehmigter Software sollten diese Einrichtungen Kontrollen durchführen, um die Verwendung nicht genehmigter Software zu verhindern oder zu erkennen, und sollten — soweit angemessen — Erkennungs- und Reaktionssoftware einsetzen. Ferner sollten die betreffenden Einrichtungen Vorkehrungen in Erwägung ziehen, um ihre Angriffsfläche zu minimieren, Schwachstellen, die durch Angreifer ausgenutzt werden können, zu verringern, die Ausführung von Anwendungen auf Endgeräten zu kontrollieren, und sie sollten E-Mail- und Web-Anwendungsfilter einsetzen, um ihre Exposition gegenüber böswilligen Inhalten zu verringern.
- (20) Gemäß Artikel 21 Absatz 2 Buchstabe g der Richtlinie (EU) 2022/2555 sollen die Mitgliedstaaten sicherstellen, dass grundlegende Verfahren im Bereich der Cyberhygiene angewandt und Schulungen im Bereich der Cybersicherheit durchgeführt werden. Zu den grundlegenden Verfahren der Cyberhygiene gehören beispielsweise Zero-Trust-Grundsätze, Software-Updates, Gerätekonfiguration, Netzwerksegmentierung, Identitäts- und Zugriffsmanagement oder Sensibilisierung der Nutzer, das Organisieren von Schulungen für die Mitarbeitenden und das Schärfen des Bewusstseins für Cyberbedrohungen, Phishing oder Social-Engineering-Techniken. Die Verfahren der Cyberhygiene sind Teil verschiedener technischer und methodischer Anforderungen der im Anhang dieser Verordnung festgelegten Risikomanagementmaßnahmen im Bereich der Cybersicherheit. In Bezug auf grundlegende Verfahren der Cyberhygiene für Nutzer sollten die betreffenden Einrichtungen beispielsweise die Vorgabe eines „leeren Schreibtischs“ und eines „leeren Bildschirms“, die Verwendung der Multi-Faktor-Authentifizierung und anderer Authentifizierungsmittel, einen sicheren Umgang mit E-Mails und ein sicheres Web-Browsen, den Schutz vor Phishing und Social Engineering und sichere Verfahren der Telearbeit in Betracht ziehen.
- (21) Um einen unbefugten Zugang zu den Anlagen und Werten der betreffenden Einrichtungen zu verhindern, sollten die betreffenden Einrichtungen ein themenspezifisches Konzept für den Zugang von Personen und von Netz- und Informationssystemen, wie z. B. zu Anwendungen, festlegen und umsetzen.
- (22) Um zu verhindern, dass Mitarbeitende beispielsweise ihre Zugangs- und Zugriffsrechte innerhalb der betreffenden Einrichtung missbrauchen können, um Schaden anzurichten, sollten die betreffenden Einrichtungen angemessene Maßnahmen für das Sicherheitsmanagement hinsichtlich ihrer Mitarbeitenden in Erwägung ziehen und ihr Personal für solche Risiken sensibilisieren. Die betreffenden Einrichtungen sollten für den Umgang mit Verstößen gegen ihre Konzepte für die Sicherheit von Netz- und Informationssystemen ein Disziplinarverfahren einführen, bekannt machen und aufrechterhalten, das in andere Disziplinarverfahren der betreffenden Einrichtung eingebettet sein kann. Zuverlässigkeitsüberprüfungen der Mitarbeitenden und — soweit anwendbar — der direkten Anbieter und Diensteanbieter der betreffenden Einrichtungen sollten dem Ziel der Sicherheit des Personals in den betreffenden Einrichtungen dienen und können Maßnahmen wie die Abfrage des Strafregistereintrags einer Person oder die Prüfung der bisherigen Erfüllung ihrer beruflichen Pflichten umfassen, soweit dies für die Aufgaben der Person in der betreffenden Einrichtung angemessen ist und mit dem Konzept der betreffenden Einrichtung für die Sicherheit von Netz- und Informationssystemen im Einklang steht.

⁽²⁾ Verordnung (EU) 2019/881 des Europäischen Parlaments und des Rates vom 17. April 2019 über die ENISA (Agentur der Europäischen Union für Cybersicherheit) und über die Zertifizierung der Cybersicherheit von Informations- und Kommunikationstechnik und zur Aufhebung der Verordnung (EU) Nr. 526/2013 (Rechtsakt zur Cybersicherheit) (ABl. L 151 vom 7.6.2019, S. 15, ELI: <http://data.europa.eu/eli/reg/2019/881/oj>).

- (23) Die Multifaktor-Authentifizierung kann die Cybersicherheit der Einrichtungen verbessern und sollte von den Einrichtungen insbesondere dann in Betracht gezogen werden, wenn Nutzer aus der Ferne auf ihre Netz- und Informationssysteme zugreifen oder wenn sie auf sensible Informationen oder privilegierte Konten und Systemverwaltungskonten zugreifen. Die Multifaktor-Authentifizierung kann mit anderen Techniken kombiniert werden, um unter bestimmten Umständen zusätzliche Faktoren zu verlangen, die auf vorab festgelegten Regeln und Mustern beruhen, z. B. beim Zugriff von einem ungewöhnlichen Standort aus, mit einem ungewöhnlichen Gerät oder zu einer ungewöhnlichen Zeit.
- (24) Die betreffenden Einrichtungen sollten ihre wichtigen Anlagen und Werte mit einem soliden Anlagen- und Wertemanagement verwalten und schützen, das auch als Grundlage für die Risikoanalyse und das Betriebskontinuitätsmanagement dienen sollte. Die betreffenden Einrichtungen sollten sowohl materielle Anlagen als auch immaterielle Werte verwalten und ein entsprechendes Anlagen- und Werteinventar erstellen, ihre Anlagen und Werte mit einer festgelegten Klassifizierung versehen, sie entsprechend behandeln und verfolgen und während ihres gesamten Lebenszyklus Maßnahmen zu ihrem Schutz treffen.
- (25) Das Anlagen- und Wertemanagement sollte eine Klassifizierung der Anlagen und Werte nach Art, Sensibilität, Risikoniveau und Sicherheitsanforderungen sowie die Durchführung geeigneter Maßnahmen und Kontrollen zur Gewährleistung ihrer Verfügbarkeit, Integrität, Vertraulichkeit und Authentizität einschließen. Durch die Klassifizierung der Anlagen und Werte nach Risikoniveau sollten die betreffenden Einrichtungen in die Lage versetzt werden, geeignete Sicherheitsmaßnahmen anzuwenden und Sicherheitskontrollen durchzuführen, um Systeme für Verschlüsselung, Zugangs- bzw. Zugriffskontrolle (einschließlich der Kontrolle des Perimeters und einer physischen und logischen Zugangskontrolle), Sicherungskopien, Protokollierung und Überwachung, Aufbewahrung und Entsorgung zu schützen. Bei der Durchführung einer Analyse der betrieblichen Auswirkungen (BIA) können die betreffenden Einrichtungen die jeweilige Klassifizierungsstufe auf der Grundlage der Folgen einer Störung der Anlagen für die Einrichtungen bestimmen. Alle Mitarbeitenden der Einrichtungen, die Anlagen und Werte verwalten, sollten mit den dafür geltenden Konzepten und Anweisungen vertraut sein.
- (26) Die Granularität des Anlagen- und Werteinventars sollte den Bedürfnissen der betreffenden Einrichtungen entsprechen. Ein umfassendes Anlagen- und Werteinventar könnte für jede Anlage bzw. jeden Wert mindestens eine eindeutige Kennung, den jeweiligen Eigentümer, eine Beschreibung, den Standort, die Art der Anlage bzw. des Wertes, die Art und Klassifizierung der damit verarbeiteten Informationen, das Datum der letzten Aktualisierung oder des letzten Patches, die bei der Risikobewertung vergebene Klassifizierung und das Ende der Lebensdauer enthalten. Bei der Identifizierung des Eigentümers einer Anlage bzw. eines Werts sollten die betreffenden Einrichtungen auch die Person angeben, die für den Schutz dieser Anlage bzw. dieses Werts verantwortlich ist.
- (27) Mit der Zuweisung und Organisation von Rollen, Verantwortlichkeiten und Weisungsbefugnissen im Bereich der Cybersicherheit sollte eine kohärente Struktur für die Governance und Umsetzung der Cybersicherheit innerhalb der betreffenden Einrichtungen geschaffen und eine wirksame Kommunikation im Falle von Sicherheitsvorfällen sichergestellt werden. Bei der Festlegung und Zuweisung von Verantwortlichkeiten für bestimmte Aufgaben sollten die betreffenden Einrichtungen bestimmte Rollen wie die des leitenden Beauftragten für die Informationssicherheit, des Beauftragten für die Informationssicherheit, des Beauftragten für die Bewältigung von Sicherheitsvorfällen, des Prüfers oder vergleichbare Funktionen berücksichtigen. Die betreffenden Einrichtungen können bestimmte Rollen und Verantwortlichkeiten auch externen Dritten wie IKT-Diensteanbietern übertragen.
- (28) Gemäß Artikel 21 Absatz 2 der Richtlinie (EU) 2022/2555 sollten Risikomanagementmaßnahmen im Bereich der Cybersicherheit auf einem gefahrenübergreifenden Ansatz beruhen, der darauf abzielt, Netz- und Informationssysteme und ihr physisches Umfeld vor Ereignissen wie Diebstahl, Feuer, Überschwemmungen und Telekommunikations- oder Stromausfällen oder vor unbefugtem physischen Zugang zu Informationen und Datenverarbeitungsanlagen einer wesentlichen oder wichtigen Einrichtung und vor der Schädigung solcher Informationen und Betriebsstätten und entsprechenden Eingriffen zu schützen, die die Verfügbarkeit, Authentizität, Integrität oder Vertraulichkeit gespeicherter, übermittelter oder verarbeiteter Daten oder der Dienste, die über Netz- und Informationssysteme angeboten werden bzw. zugänglich sind, beeinträchtigen können. In den technischen und methodischen Anforderungen der Risikomanagementmaßnahmen im Bereich der Cybersicherheit sollten daher auch die physische Sicherheit der Netz- und Informationssysteme und die Sicherheit ihres Umfelds berücksichtigt werden, indem Maßnahmen zum Schutz dieser Systeme vor Systemfehlern, menschlichen Fehlern, böswilligen Handlungen oder natürlichen Phänomenen darin einbezogen werden. Weitere physische Bedrohungen und Bedrohungen des Umfelds ergeben sich z. B. aus Erdbeben, Explosionen, Sabotage, Insider-Bedrohungen, Unruhen, giftigen Abfällen und Umweltemissionen. Die Verhinderung von Verlusten, Beschädigungen oder Beeinträchtigungen von Netz- und Informationssystemen oder von Betriebsunterbrechungen infolge des Ausfalls und der Störung unterstützender Versorgungsleistungen sollte ebenfalls zur angestrebten Betriebskontinuität in den betreffenden Einrichtungen beitragen. Darüber hinaus sollte sich durch den Schutz vor physischen Bedrohungen und Bedrohungen des Umfelds auch die Sicherheit bei der Wartung von Netz- und Informationssystemen in den betreffenden Einrichtungen erhöhen.

- (29) Die betreffenden Einrichtungen sollten Maßnahmen zum Schutz vor physischen Bedrohungen und Bedrohungen des Umfelds konzipieren und umsetzen, Mindest- und Höchstkontrollwerte für solche Bedrohungen festlegen und Umweltparameter überwachen. So sollten sie beispielsweise die Installation von Früherkennungssystemen für die Überschwemmung von Gebieten, in denen sich Netz- und Informationssysteme befinden, in Erwägung ziehen. In Bezug auf Brandgefahren sollten die betreffenden Einrichtungen insbesondere die Schaffung eines separaten Brandabschnitts für das Rechenzentrum, den Einsatz feuerbeständiger Materialien, die Anbringung von Sensoren zur Überwachung von Temperatur und Feuchtigkeit, den Anschluss des Gebäudes an eine Brandmeldeanlage mit automatischer Benachrichtigung der örtlichen Feuerwehr sowie Brandfrüherkennungs- und Feuerlöschanlagen in Erwägung ziehen. Überdies sollten die betreffenden Einrichtungen regelmäßig Brandschutzübungen und Brandschutzinspektionen durchführen. Um ihre Stromversorgung sicherzustellen, sollten die betreffenden Einrichtungen außerdem einen Überspannungsschutz und eine entsprechende Notstromversorgung nach den einschlägigen Normen in Erwägung ziehen. Da Überhitzung eine Gefahr für die Verfügbarkeit von Netz- und Informationssystemen darstellt, könnten die betreffenden Einrichtungen, insbesondere Anbieter von Rechenzentrumsdiensten, auch den Einbau angemessener, kontinuierlicher und redundanter Klimaanlage in Erwägung ziehen.
- (30) Ferner soll in dieser Verordnung präzisiert werden, in welchen Fällen ein Sicherheitsvorfall für die Zwecke des Artikels 23 Absatz 3 der Richtlinie (EU) 2022/2555 als erheblich angesehen werden sollte. Die Kriterien sollten so gestaltet sein, dass die betreffenden Einrichtungen beurteilen können, ob ein Sicherheitsvorfall erheblich ist, um ihn dann gemäß der Richtlinie (EU) 2022/2555 zu melden. Darüber hinaus sollten die in dieser Verordnung festgelegten Kriterien unbeschadet des Artikels 5 der Richtlinie (EU) 2022/2555 als erschöpfend betrachtet werden. In dieser Verordnung werden die Fälle festgelegt, in denen ein Sicherheitsvorfall als erheblich angesehen werden sollte; dazu werden sowohl horizontale als auch einrichtungsspezifische Fälle festgelegt.
- (31) Gemäß Artikel 23 Absatz 4 der Richtlinie (EU) 2022/2555 sollten die betreffenden Einrichtungen dazu verpflichtet sein, erhebliche Sicherheitsvorfälle innerhalb der in dieser Bestimmung festgelegten Fristen zu melden. Diese Meldefristen laufen ab dem Zeitpunkt, zu dem die Einrichtung Kenntnis von solchen erheblichen Vorfällen erlangt. Die betreffende Einrichtung muss daher Sicherheitsvorfälle melden, die nach der von ihr vorgenommenen Anfangsbewertung schwerwiegende Betriebsstörungen des Dienstes oder finanzielle Verluste für diese Einrichtung verursachen oder andere natürliche oder juristische Personen beeinträchtigen könnten, indem sie erhebliche materielle oder immaterielle Schäden nach sich ziehen. Wenn also eine betreffende Einrichtung ein verdächtiges Ereignis feststellt oder ihr ein mutmaßlicher Sicherheitsvorfall von einem Dritten, z. B. von einer Person, einem Kunden, einer Einrichtung, einer Behörde, einer Medienorganisation oder aus anderer Quelle, zur Kenntnis gebracht wird, sollte sie das verdächtige Ereignis zeitnah bewerten, um festzustellen, ob es sich um einen Sicherheitsvorfall handelt, und, falls dies der Fall ist, seine Art und Schwere zu bestimmen. Es ist daher davon auszugehen, dass die betreffende Einrichtung von dem erheblichen Sicherheitsvorfall Kenntnis hatte, sobald sie nach einer solchen Anfangsbewertung mit hinreichender Gewissheit feststellt, dass ein erheblicher Sicherheitsvorfall vorliegt.
- (32) Im Hinblick auf die Feststellung, ob ein Sicherheitsvorfall erheblich ist, sollten die betreffenden Einrichtungen — soweit zutreffend — die Zahl der von dem Sicherheitsvorfall betroffenen Nutzer ermitteln, wobei sie Geschäfts- und Endkunden, mit denen die betreffenden Einrichtungen eine Vertragsbeziehung unterhalten, sowie natürliche und juristische Personen, die mit den Geschäftskunden in Verbindung stehen, berücksichtigen sollten. Ist eine betreffende Einrichtung nicht imstande, die Zahl der betroffenen Nutzer zu berechnen, sollte sie bei der Bestimmung der Gesamtzahl der von dem Sicherheitsvorfall betroffenen Nutzer ihre Schätzung der möglichen Höchstzahl betroffener Nutzer zugrunde legen. Die Bedeutung eines Sicherheitsvorfalls, an dem ein Vertrauensdienst beteiligt ist, sollte nicht nur anhand der Zahl der Nutzer, sondern auch der Zahl der vertrauenden Beteiligten bestimmt werden, da diese im Hinblick auf Betriebsstörungen und materielle oder immaterielle Schäden gleichermaßen von einem erheblichen Vorfall, an dem ein Vertrauensdienst beteiligt ist, beeinträchtigt werden können. Deshalb sollten Vertrauensdiensteanbieter bei ihrer Feststellung, ob ein Sicherheitsvorfall erheblich ist, — soweit anwendbar — auch die Zahl der vertrauenden Beteiligten berücksichtigen. Zu diesem Zweck sollten vertrauende Beteiligte als natürliche oder juristische Personen verstanden werden, die einen Vertrauensdienst in Anspruch nehmen.
- (33) Wartungsarbeiten, die zu einer eingeschränkten Verfügbarkeit oder zur Nichtverfügbarkeit der Dienste führen, sollten nicht als erhebliche Sicherheitsvorfälle angesehen werden, wenn die eingeschränkte Verfügbarkeit oder Nichtverfügbarkeit des Dienstes im Rahmen eines planmäßigen Wartungsvorgangs eintritt. Darüber hinaus sollte es nicht als erheblicher Sicherheitsvorfall angesehen werden, wenn ein Dienst aufgrund planmäßiger Unterbrechungen wie etwa im Voraus vertraglich vereinbarter Unterbrechungen oder Nichtverfügbarkeiten nicht verfügbar ist.

- (34) Die Dauer eines Sicherheitsvorfalls, der die Verfügbarkeit eines Dienstes beeinträchtigt, sollte ab dem Beginn der Störung der ordnungsgemäßen Erbringung des Dienstes bis zum Zeitpunkt der Wiederherstellung gemessen werden. Wenn eine betreffende Einrichtung nicht imstande ist, den Zeitpunkt des Beginns der Störung zu bestimmen, sollte die Dauer des Sicherheitsvorfalls ab dem Zeitpunkt gemessen werden, zu dem der Sicherheitsvorfall erkannt wurde, oder ab dem Zeitpunkt, zu dem der Sicherheitsvorfall in Netz- oder Systemprotokollen oder anderen Datenquellen aufgezeichnet wurde, je nachdem, welcher Zeitpunkt früher ist.
- (35) Eine vollständige Nichtverfügbarkeit eines Dienstes sollte von dem Zeitpunkt an gemessen werden, zu dem der Dienst für die Nutzer vollständig nicht verfügbar ist, bis zu dem Zeitpunkt, zu dem die gewöhnlichen Tätigkeiten oder Abläufe wieder das vor dem Sicherheitsvorfall bestehende Dienstniveau erreicht haben. Wenn eine betreffende Einrichtung nicht imstande ist, den Zeitpunkt des Beginns der vollständigen Nichtverfügbarkeit eines Dienstes zu bestimmen, sollte die Nichtverfügbarkeit ab dem Zeitpunkt gemessen werden, zu dem sie von der Einrichtung festgestellt wurde.
- (36) Bei der Bestimmung der direkten finanziellen Verluste infolge eines Sicherheitsvorfalls sollten die betreffenden Einrichtungen alle finanziellen Verluste berücksichtigen, die ihnen infolge des Sicherheitsvorfalls entstanden sind, wie etwa Kosten für die Ersetzung oder Verlegung von Software, Hardware oder Infrastruktur, Personalkosten, einschließlich Kosten im Zusammenhang mit der Ersetzung oder Verlegung von Personal, der Einstellung zusätzlichen Personals, der Vergütung von Überstunden und der Wiederherstellung verloren gegangener oder beeinträchtigter Kompetenzen, Gebühren wegen Nichteinhaltung vertraglicher Verpflichtungen, Kosten für Ausgleichs- und Entschädigungszahlungen an Kunden, Verluste wegen entgangener Einnahmen, Kosten für interne und externe Kommunikation, Beratungskosten, einschließlich Kosten im Zusammenhang mit Rechtsberatung, forensischen Dienstleistungen und Behebungsdienstleistungen, und sonstige Kosten im Zusammenhang mit dem Sicherheitsvorfall. Geldbußen wie auch Kosten, die für den laufenden Geschäftsbetrieb erforderlich sind, sollten jedoch nicht als finanzielle Verluste infolge eines Sicherheitsvorfalls betrachtet werden, darunter etwa Kosten für die allgemeine Wartung von Infrastruktur, Ausrüstung, Hardware und Software, Kosten für die laufende Fortbildung des Personals, um dessen Kompetenzen auf dem aktuellen Stand zu halten, interne oder externe Kosten für die Verstärkung des Geschäftsbetriebs nach dem Vorfall, einschließlich für Aufrüstungen, Verbesserungen und Initiativen zur Risikobewertung, sowie Versicherungsprämien. Die betreffenden Einrichtungen sollten die Höhe der finanziellen Verluste auf der Grundlage vorliegender Daten berechnen, und wenn die tatsächliche Höhe der finanziellen Verluste nicht bestimmt werden kann, sollten die Einrichtungen solche Beträge schätzen.
- (37) Die betreffenden Einrichtungen sollten auch verpflichtet sein, Sicherheitsvorfälle zu melden, die den Tod natürlicher Personen oder erhebliche Schädigungen der Gesundheit natürlicher Personen verursacht haben oder verursachen können, denn bei solchen Vorfällen handelt es sich um besonders schwere Fälle, die erhebliche materielle oder immaterielle Schäden verursachen. So könnte beispielsweise ein Sicherheitsvorfall, der eine betreffende Einrichtung beeinträchtigt, dazu führen, dass Gesundheits- oder Notdienste nicht zur Verfügung stehen oder dass die Vertraulichkeit oder Integrität von Daten verloren geht und sich dies auf die Gesundheit natürlicher Personen auswirkt. Bei der Feststellung, ob ein Sicherheitsvorfall erhebliche Schädigungen der Gesundheit einer natürlichen Person verursacht hat oder verursachen kann, sollten die betreffenden Einrichtungen berücksichtigen, ob der Vorfall schwere Verletzungen und Erkrankungen verursacht hat oder verursachen kann. In dieser Hinsicht sollten die betreffenden Einrichtungen nicht dazu verpflichtet sein, zusätzliche Informationen einzuholen, die ihnen nicht zugänglich sind.
- (38) Von einer eingeschränkten Verfügbarkeit sollte insbesondere dann ausgegangen werden, wenn ein von einer betreffenden Einrichtung erbrachter Dienst deutlich langsamer als die durchschnittliche Antwortzeit ist oder wenn nicht alle Funktionen eines Dienstes verfügbar sind. Zur Bewertung von Verzögerungen bei der Antwortzeit sollten — soweit möglich — objektive Kriterien auf der Grundlage der durchschnittlichen Antwortzeiten der von den betreffenden Einrichtungen erbrachten Dienste herangezogen werden. Eine Funktion eines Dienstes kann beispielsweise aus einer Chat-Funktion oder einer Bildsuchfunktion bestehen.
- (39) Ein erfolgreicher, mutmaßlich böswilliger und unbefugter Zugriff auf Netz- und Informationssysteme einer betreffenden Einrichtung sollte als erheblicher Sicherheitsvorfall betrachtet werden, wenn er zu schwerwiegenden Betriebsstörungen führen kann. Wenn sich beispielsweise ein Cyberangreifer in den Netz- und Informationssystemen einer betreffenden Einrichtung einnistet, um künftig eine Störung der Dienste zu verursachen, sollte der Sicherheitsvorfall als erheblich betrachtet werden.

- (40) Wiederholte Sicherheitsvorfälle, die offensichtlich dieselbe Ursache haben und einzeln betrachtet die Kriterien für einen erheblichen Sicherheitsvorfall nicht erfüllen, sollten zusammen dennoch als erheblicher Sicherheitsvorfall betrachtet werden, sofern sie zusammen das Kriterium für finanzielle Verluste erfüllen und zumindest zweimal innerhalb von sechs Monaten aufgetreten sind. Solche wiederholten Sicherheitsvorfälle können auf erhebliche Mängel und Schwächen in den Verfahren für das Cybersicherheitsrisikomanagement der betreffenden Einrichtung und deren Reifegrad im Bereich der Cybersicherheit hindeuten. Darüber hinaus können solche wiederholten Sicherheitsvorfälle erhebliche finanzielle Verluste bei der betreffenden Einrichtung verursachen.
- (41) Die Kommission hat sich mit der Kooperationsgruppe und der ENISA über den Entwurf des Durchführungsrechtsakts gemäß Artikel 21 Absatz 5 und Artikel 23 Absatz 11 der Richtlinie (EU) 2022/2555 ausgetauscht und mit ihnen zusammengearbeitet.
- (42) Der Europäische Datenschutzbeauftragte wurde gemäß Artikel 42 Absatz 1 der Verordnung (EU) 2018/1725 des Europäischen Parlaments und des Rates ⁽⁷⁾ angehört und gab am 1. September 2024 seine Stellungnahme ab.
- (43) Die in dieser Verordnung vorgesehenen Maßnahmen entsprechen der Stellungnahme des nach Artikel 39 der Richtlinie (EU) 2022/2555 eingesetzten Ausschusses —

HAT FOLGENDE VERORDNUNG ERLASSEN:

Artikel 1

Gegenstand

In dieser Verordnung werden in Bezug auf DNS-Diensteanbieter, TLD-Namenregister, Anbieter von Cloud-Computing-Diensten, Anbieter von Rechenzentrumsdiensten, Betreiber von Inhaltzustellnetzen, Anbieter verwalteter Dienste, Anbieter verwalteter Sicherheitsdienste, Anbieter von Online-Marktplätzen, Online-Suchmaschinen und Plattformen für Dienste sozialer Netzwerke und Vertrauensdiensteanbieter (im Folgenden „betreffende Einrichtungen“) die technischen und methodischen Anforderungen der in Artikel 21 Absatz 2 der Richtlinie (EU) 2022/2555 genannten Maßnahmen festgelegt und die Fälle präzisiert, in denen ein Sicherheitsvorfall gemäß Artikel 23 Absatz 3 der Richtlinie (EU) 2022/2555 als erheblich anzusehen ist.

Artikel 2

Technische und methodische Anforderungen

- (1) Für die betreffenden Einrichtungen sind im Anhang dieser Verordnung die technischen und methodischen Anforderungen der in Artikel 21 Absatz 2 Buchstaben a bis j der Richtlinie (EU) 2022/2555 genannten Risikomanagementmaßnahmen im Bereich der Cybersicherheit festgelegt.
- (2) Bei der Umsetzung und Anwendung der technischen und methodischen Anforderungen der im Anhang dieser Verordnung festgelegten Risikomanagementmaßnahmen im Bereich der Cybersicherheit gewährleisten die betreffenden Einrichtungen ein den bestehenden Risiken angemessenes Sicherheitsniveau der Netz- und Informationssysteme. Zu diesem Zweck tragen sie dem Ausmaß ihrer Risikoexposition, ihrer Größe und der Wahrscheinlichkeit des Eintretens von Sicherheitsvorfällen und deren Schwere, einschließlich gesellschaftlicher und wirtschaftlicher Auswirkungen, gebührend Rechnung, wenn sie die im Anhang dieser Verordnung festgelegten technischen und methodischen Anforderungen der Risikomanagementmaßnahmen im Bereich der Cybersicherheit erfüllen.

⁽⁷⁾ Verordnung (EU) 2018/1725 des Europäischen Parlaments und des Rates vom 23. Oktober 2018 zum Schutz natürlicher Personen bei der Verarbeitung personenbezogener Daten durch die Organe, Einrichtungen und sonstigen Stellen der Union, zum freien Datenverkehr und zur Aufhebung der Verordnung (EG) Nr. 45/2001 und des Beschlusses Nr. 1247/2002/EG (ABl. L 295 vom 21.11.2018, S. 39, ELI: <http://data.europa.eu/eli/reg/2018/1725/oj>).

Ist im Anhang dieser Verordnung vorgesehen, dass eine technische oder methodische Anforderung einer Risikomanagementmaßnahmen im Bereich der Cybersicherheit nur anzuwenden ist, soweit dies angemessen, anwendbar oder durchführbar ist, und hält es eine betreffende Einrichtung für nicht angemessen, nicht anwendbar oder nicht durchführbar, bestimmte technische und methodische Anforderungen anzuwenden, so muss die betreffende Einrichtung ihre diesbezügliche Begründung in verständlicher Weise dokumentieren.

Artikel 3

Erhebliche Sicherheitsvorfälle

(1) Ein Sicherheitsvorfall gilt in Bezug auf die betreffenden Einrichtungen als erheblich im Sinne von Artikel 23 Absatz 3 der Richtlinie (EU) 2022/2555, wenn eines oder mehrere der folgenden Kriterien erfüllt sind:

- a) der Vorfall hat der betreffenden Einrichtung einen direkten finanziellen Verlust in Höhe von mehr als 500 000 EUR oder 5 % ihres jährlichen Gesamtumsatzes im vorangegangenen Geschäftsjahr — je nachdem, welcher Wert niedriger ist — verursacht oder kann einen solchen Verlust verursachen;
- b) der Vorfall hat den Abfluss von Geschäftsgeheimnissen der betreffenden Einrichtung im Sinne von Artikel 2 Nummer 1 der Richtlinie (EU) 2016/943 verursacht oder kann einen solchen Abfluss verursachen;
- c) der Vorfall hat den Tod einer natürlichen Person verursacht oder kann einen solchen Tod verursachen;
- d) der Vorfall hat eine schwere Schädigung der Gesundheit einer natürlichen Person verursacht oder kann eine solche Schädigung verursachen;
- e) es hat einen erfolgreichen, mutmaßlich böswilligen und unbefugten Zugriff auf Netz- und Informationssysteme gegeben, der geeignet ist, schwerwiegende Betriebsstörungen zu verursachen;
- f) der Vorfall erfüllt die in Artikel 4 aufgeführten Kriterien;
- g) der Vorfall erfüllt eines oder mehrere der in den Artikeln 5 bis 14 aufgeführten Kriterien.

(2) Planmäßige Betriebsunterbrechungen und geplante Folgen planmäßiger Wartungsarbeiten, die von oder im Auftrag der betreffenden Einrichtungen durchgeführt werden, gelten nicht als erhebliche Sicherheitsvorfälle.

(3) Bei der Berechnung der Zahl der von einem Sicherheitsvorfall betroffenen Nutzer für die Zwecke der Artikel 7 und Artikel 9 bis 14 berücksichtigen die betreffenden Einrichtungen Folgendes:

- a) die Zahl der Kunden, die mit der betreffenden Einrichtung einen Vertrag geschlossen haben, der ihnen Zugang zu den Netz- und Informationssystemen der betreffenden Einrichtung oder über diese Netz- und Informationssysteme angebotenen oder zugänglichen Diensten verschafft;
- b) die Zahl der natürlichen oder juristischen Personen, die mit Geschäftskunden verbunden sind, die Netz- und Informationssysteme der betreffenden Einrichtung oder über diese Netz- und Informationssysteme angebotene oder zugängliche Diensten nutzen.

Artikel 4

Wiederholte Sicherheitsvorfälle

Sicherheitsvorfälle, die einzeln betrachtet nach Artikel 3 nicht als erhebliche Sicherheitsvorfälle angesehen werden, gelten zusammengekommen als ein erheblicher Sicherheitsvorfall, wenn sie alle folgenden Kriterien erfüllen:

- a) sie sind innerhalb von sechs Monaten mindestens zwei Mal aufgetreten;
- b) sie haben dieselbe offensichtliche Ursache;
- c) sie erfüllen zusammengekommen die in Artikel 3 Absatz 1 Buchstabe a aufgeführten Kriterien.

*Artikel 5***Erhebliche Sicherheitsvorfälle in Bezug auf DNS-Diensteanbieter**

In Bezug auf DNS-Diensteanbieter gilt ein Sicherheitsvorfall als erheblich im Sinne von Artikel 3 Absatz 1 Buchstabe g, wenn er eines oder mehrere der folgenden Kriterien erfüllt:

- a) ein rekursiver oder autoritativer Dienst zur Auflösung von Domännennamen ist mehr als 30 Minuten lang vollständig nicht verfügbar;
- b) mehr als eine Stunde lang beträgt die durchschnittliche Antwortzeit eines rekursiven oder autoritativen Dienstes zur Auflösung von Domännennamen auf DNS-Anfragen mehr als 10 Sekunden;
- c) die Integrität, Vertraulichkeit oder Authentizität der Daten, die im Zusammenhang mit der Bereitstellung des autoritativen Dienstes zur Auflösung von Domännennamen gespeichert, übermittelt oder verarbeitet werden, ist beeinträchtigt, außer falls die Daten von weniger als 1 000 Domännennamen, die von dem DNS-Diensteanbieter verwaltet werden und die höchstens 1 % der von dem DNS-Diensteanbieter verwalteten Domännennamen ausmachen, aufgrund einer Fehlkonfiguration nicht korrekt sind.

*Artikel 6***Erhebliche Sicherheitsvorfälle in Bezug auf TLD-Namenregister**

In Bezug auf TLD-Namenregister gilt ein Sicherheitsvorfall als erheblich im Sinne von Artikel 3 Absatz 1 Buchstabe g, wenn er eines oder mehrere der folgenden Kriterien erfüllt:

- a) ein autoritativer Dienst zur Auflösung von Domännennamen ist vollständig nicht verfügbar;
- b) mehr als eine Stunde lang beträgt die durchschnittliche Antwortzeit eines autoritativen Dienstes zur Auflösung von Domännennamen auf DNS-Anfragen mehr als 10 Sekunden;
- c) die Integrität, Vertraulichkeit oder Authentizität der im Zusammenhang mit dem technischen Betrieb der TLD gespeicherten, übermittelten oder verarbeiteten Daten ist beeinträchtigt.

*Artikel 7***Erhebliche Sicherheitsvorfälle in Bezug auf Anbieter von Cloud-Computing-Diensten**

In Bezug auf Anbieter von Cloud-Computing-Diensten gilt ein Sicherheitsvorfall als erheblich im Sinne von Artikel 3 Absatz 1 Buchstabe g, wenn er eines oder mehrere der folgenden Kriterien erfüllt:

- a) ein erbrachter Cloud-Computing-Dienst ist mehr als 30 Minuten lang vollständig nicht verfügbar;
- b) die Verfügbarkeit eines Cloud-Computing-Dienstes eines Anbieters ist für mehr als 5 % der Nutzer des Cloud-Computing-Dienstes in der Union oder für mehr als 1 Mio. Nutzer des Cloud-Computing-Dienstes in der Union — je nachdem, welche Zahl niedriger ist — für eine Dauer von mehr als einer Stunde eingeschränkt;
- c) die Integrität, Vertraulichkeit oder Authentizität der im Zusammenhang mit der Erbringung eines Cloud-Computing-Dienstes gespeicherten, übermittelten oder verarbeiteten Daten ist infolge einer mutmaßlich böswilligen Handlung beeinträchtigt;
- d) die Integrität, Vertraulichkeit oder Authentizität der im Zusammenhang mit der Erbringung eines Cloud-Computing-Dienstes gespeicherten, übermittelten oder verarbeiteten Daten ist beeinträchtigt, und dies wirkt sich auf mehr als 5 % der Nutzer des Cloud-Computing-Dienstes in der Union oder auf mehr als 1 Mio. Nutzer des Cloud-Computing-Dienstes in der Union — je nachdem, welche Zahl niedriger ist — aus.

*Artikel 8***Erhebliche Sicherheitsvorfälle in Bezug auf Anbieter von Rechenzentrumsdiensten**

In Bezug auf Anbieter von Rechenzentrumsdiensten gilt ein Sicherheitsvorfall als erheblich im Sinne von Artikel 3 Absatz 1 Buchstabe g, wenn er eines oder mehrere der folgenden Kriterien erfüllt:

- a) ein Rechenzentrumsdienst eines vom Anbieter betriebenen Rechenzentrums ist vollständig nicht verfügbar;
- b) die Verfügbarkeit eines Rechenzentrumsdienstes eines vom Anbieter betriebenen Rechenzentrums ist für eine Dauer von mehr als einer Stunde eingeschränkt;

- c) die Integrität, Vertraulichkeit oder Authentizität der im Zusammenhang mit der Erbringung eines Rechenzentrumsdienstes gespeicherten, übermittelten oder verarbeiteten Daten ist infolge einer mutmaßlich böswilligen Handlung beeinträchtigt;
- d) der physische Zugang zu einem von dem Anbieter betriebenen Rechenzentrum ist beeinträchtigt.

Artikel 9

Erhebliche Sicherheitsvorfälle in Bezug auf Betreiber von Inhaltszustellnetzen

In Bezug auf Betreiber von Inhaltszustellnetzen gilt ein Sicherheitsvorfall als erheblich im Sinne von Artikel 3 Absatz 1 Buchstabe g, wenn er eines oder mehrere der folgenden Kriterien erfüllt:

- a) ein Inhaltszustellnetz ist mehr als 30 Minuten lang vollständig nicht verfügbar;
- b) die Verfügbarkeit eines Inhaltszustellnetzes ist für mehr als 5 % der Nutzer des Inhaltszustellnetzes in der Union oder für mehr als 1 Mio. Nutzer des Inhaltszustellnetzes in der Union — je nachdem, welche Zahl niedriger ist — für eine Dauer von mehr als einer Stunde eingeschränkt;
- c) die Integrität, Vertraulichkeit oder Authentizität der im Zusammenhang mit dem Betrieb eines Inhaltszustellnetzes gespeicherten, übermittelten oder verarbeiteten Daten ist infolge einer mutmaßlich böswilligen Handlung beeinträchtigt;
- d) die Integrität, Vertraulichkeit oder Authentizität der im Zusammenhang mit dem Betrieb eines Inhaltszustellnetzes gespeicherten, übermittelten oder verarbeiteten Daten ist beeinträchtigt, und dies wirkt sich auf mehr als 5 % der Nutzer des Inhaltszustellnetzes in der Union oder auf mehr als 1 Mio. Nutzer des Inhaltszustellnetzes in der Union — je nachdem, welche Zahl niedriger ist — aus.

Artikel 10

Erhebliche Sicherheitsvorfälle in Bezug Anbieter verwalteter Dienste und Anbieter verwalteter Sicherheitsdienste

In Bezug auf Anbieter verwalteter Dienste und Anbieter verwalteter Sicherheitsdienste gilt ein Sicherheitsvorfall als erheblich im Sinne von Artikel 3 Absatz 1 Buchstabe g, wenn er eines oder mehrere der folgenden Kriterien erfüllt:

- a) ein verwalteter Dienst oder ein verwalteter Sicherheitsdienst ist mehr als 30 Minuten lang vollständig nicht verfügbar;
- b) die Verfügbarkeit eines verwalteten Dienstes oder verwalteten Sicherheitsdienstes ist für mehr als 5 % der Nutzer des Dienstes in der Union oder für mehr als 1 Mio. Nutzer des Dienstes in der Union — je nachdem, welche Zahl niedriger ist — für eine Dauer von mehr als einer Stunde eingeschränkt;
- c) die Integrität, Vertraulichkeit oder Authentizität der im Zusammenhang mit der Erbringung eines verwalteten Dienstes oder verwalteten Sicherheitsdienstes gespeicherten, übermittelten oder verarbeiteten Daten ist infolge einer mutmaßlich böswilligen Handlung beeinträchtigt;
- d) die Integrität, Vertraulichkeit oder Authentizität der im Zusammenhang mit der Erbringung eines verwalteten Dienstes oder verwalteten Sicherheitsdienstes gespeicherten, übermittelten oder verarbeiteten Daten ist beeinträchtigt, und dies wirkt sich auf mehr als 5 % der Nutzer des Dienstes in der Union oder auf mehr als 1 Mio. Nutzer des Dienstes in der Union — je nachdem, welche Zahl niedriger ist — aus.

Artikel 11

Erhebliche Sicherheitsvorfälle in Bezug auf Anbieter von Online-Marktplätzen

In Bezug auf Anbieter von Online-Marktplätzen gilt ein Sicherheitsvorfall als erheblich im Sinne von Artikel 3 Absatz 1 Buchstabe g, wenn er eines oder mehrere der folgenden Kriterien erfüllt:

- a) ein Online-Marktplatz ist für mehr als 5 % der Nutzer des Online-Marktplatzes in der Union oder für mehr als 1 Mio. Nutzer des Online-Marktplatzes in der Union — je nachdem, welche Zahl niedriger ist — vollständig nicht verfügbar;

- b) mehr als 5 % der Nutzer eines Online-Marktplatzes in der Union oder mehr als 1 Mio. Nutzer eines Online-Marktplatzes in der Union — je nachdem, welche Zahl niedriger ist — sind von einer eingeschränkten Verfügbarkeit des Online-Marktplatzes betroffen;
- c) die Integrität, Vertraulichkeit oder Authentizität der im Zusammenhang mit dem Betrieb eines Online-Marktplatzes gespeicherten, übermittelten oder verarbeiteten Daten ist infolge einer mutmaßlich böswilligen Handlung beeinträchtigt;
- d) die Integrität, Vertraulichkeit oder Authentizität der im Zusammenhang mit dem Betrieb eines Online-Marktplatzes gespeicherten, übermittelten oder verarbeiteten Daten ist beeinträchtigt, und dies wirkt sich auf mehr als 5 % der Nutzer des Online-Marktplatzes in der Union oder auf mehr als 1 Mio. Nutzer des Online-Marktplatzes in der Union — je nachdem, welche Zahl niedriger ist — aus.

Artikel 12

Erhebliche Sicherheitsvorfälle in Bezug auf Anbieter von Online-Suchmaschinen

In Bezug auf Anbieter von Online-Suchmaschinen gilt ein Sicherheitsvorfall als erheblich im Sinne von Artikel 3 Absatz 1 Buchstabe g, wenn er eines oder mehrere der folgenden Kriterien erfüllt:

- a) eine Online-Suchmaschine ist für mehr als 5 % der Nutzer der Online-Suchmaschine in der Union oder für mehr als 1 Mio. Nutzer der Online-Suchmaschine in der Union — je nachdem, welche Zahl niedriger ist — vollständig nicht verfügbar;
- b) mehr als 5 % der Nutzer einer Online-Suchmaschine in der Union oder mehr als 1 Mio. Nutzer einer Online-Suchmaschine in der Union — je nachdem, welche Zahl niedriger ist — sind von einer eingeschränkten Verfügbarkeit der Online-Suchmaschine betroffen;
- c) die Integrität, Vertraulichkeit oder Authentizität der im Zusammenhang mit dem Betrieb einer Online-Suchmaschine gespeicherten, übermittelten oder verarbeiteten Daten ist infolge einer mutmaßlich böswilligen Handlung beeinträchtigt;
- d) die Integrität, Vertraulichkeit oder Authentizität der im Zusammenhang mit dem Betrieb einer Online-Suchmaschine gespeicherten, übermittelten oder verarbeiteten Daten ist beeinträchtigt, und dies wirkt sich auf mehr als 5 % der Nutzer der Online-Suchmaschine in der Union oder auf mehr als 1 Mio. Nutzer der Online-Suchmaschine in der Union — je nachdem, welche Zahl niedriger ist — aus.

Artikel 13

Erhebliche Sicherheitsvorfälle in Bezug auf Anbieter von Plattformen für Dienste sozialer Netzwerke

In Bezug auf Anbieter von Plattformen für Dienste sozialer Netzwerke gilt ein Sicherheitsvorfall als erheblich im Sinne von Artikel 3 Absatz 1 Buchstabe g, wenn er eines oder mehrere der folgenden Kriterien erfüllt:

- a) eine Plattform für Dienste sozialer Netzwerke ist für mehr als 5 % der Nutzer der Plattform für Dienste sozialer Netzwerke in der Union oder für mehr als 1 Mio. Nutzer der Plattform für Dienste sozialer Netzwerke in der Union — je nachdem, welche Zahl niedriger ist — vollständig nicht verfügbar;
- b) mehr als 5 % der Nutzer einer Plattform für Dienste sozialer Netzwerke in der Union oder mehr als 1 Mio. Nutzer einer Plattform für Dienste sozialer Netzwerke in der Union — je nachdem, welche Zahl niedriger ist — sind von einer eingeschränkten Verfügbarkeit der Plattform für Dienste sozialer Netzwerke betroffen;
- c) die Integrität, Vertraulichkeit oder Authentizität der im Zusammenhang mit dem Betrieb einer Plattform für Dienste sozialer Netzwerke gespeicherten, übermittelten oder verarbeiteten Daten ist infolge einer mutmaßlich böswilligen Handlung beeinträchtigt;
- d) die Integrität, Vertraulichkeit oder Authentizität der im Zusammenhang mit dem Betrieb einer Plattform für Dienste sozialer Netzwerke gespeicherten, übermittelten oder verarbeiteten Daten ist beeinträchtigt, und dies wirkt sich auf mehr als 5 % der Nutzer der Plattform für Dienste sozialer Netzwerke in der Union oder auf mehr als 1 Mio. Nutzer der Plattform für Dienste sozialer Netzwerke in der Union — je nachdem, welche Zahl niedriger ist — aus.

Artikel 14

Erhebliche Sicherheitsvorfälle in Bezug auf Vertrauensdiensteanbieter

In Bezug auf Vertrauensdiensteanbieter gilt ein Sicherheitsvorfall als erheblich im Sinne von Artikel 3 Absatz 1 Buchstabe g, wenn er eines oder mehrere der folgenden Kriterien erfüllt:

- a) ein Vertrauensdienst ist mehr als 20 Minuten lang vollständig nicht verfügbar;
- b) ein Vertrauensdienst ist für Nutzer oder vertrauende Beteiligte im Laufe einer Kalenderwoche mehr als eine Stunde lang nicht verfügbar;
- c) mehr als 1 % der Nutzer oder vertrauenden Beteiligten in der Union oder mehr als 200 000 Nutzer oder vertrauende Beteiligte in der Union — je nachdem, welche Zahl niedriger ist — sind von einer eingeschränkten Verfügbarkeit eines Vertrauensdienstes betroffen;
- d) der physische Zugang zu einem Bereich, in dem sich Netz- und Informationssysteme befinden und zu dem nur vertrauenswürdiges Personal des Vertrauensdiensteanbieters Zugang hat, oder der Schutz dieses physischen Zugangs ist beeinträchtigt;
- e) die Integrität, Vertraulichkeit oder Authentizität der im Zusammenhang mit der Erbringung eines Vertrauensdienstes gespeicherten, übermittelten oder verarbeiteten Daten ist beeinträchtigt, und dies wirkt sich auf mehr als 0,1 % der Nutzer oder vertrauenden Beteiligten oder auf mehr als 100 Nutzer oder vertrauende Beteiligte des Vertrauensdienstes in der Union — je nachdem, welche Zahl niedriger ist — aus.

Artikel 15

Aufhebung

Die Durchführungsverordnung (EU) 2018/151 der Kommission ⁽⁴⁾ wird aufgehoben.

Artikel 16

Inkrafttreten und Geltungsbeginn

Diese Verordnung tritt am zwanzigsten Tag nach ihrer Veröffentlichung im *Amtsblatt der Europäischen Union* in Kraft.

Diese Verordnung ist in allen ihren Teilen verbindlich und gilt unmittelbar in jedem Mitgliedstaat.

Brüssel, den 17. Oktober 2024

Für die Kommission

Die Präsidentin

Ursula VON DER LEYEN

⁽⁴⁾ Durchführungsverordnung (EU) 2018/151 der Kommission vom 30. Januar 2018 über Vorschriften für die Anwendung der Richtlinie (EU) 2016/1148 des Europäischen Parlaments und des Rates hinsichtlich der weiteren Festlegung der von Anbietern digitaler Dienste beim Risikomanagement in Bezug auf die Sicherheit von Netz- und Informationssystemen zu berücksichtigenden Elemente und der Parameter für die Feststellung erheblicher Auswirkungen eines Sicherheitsvorfalls (ABl. L 26 vom 31.1.2018, S. 48, ELI: http://data.europa.eu/eli/reg_impl/2018/151/oj).

ANHANG

Technische und methodische Anforderungen gemäß Artikel 2 der vorliegenden Verordnung**1. Konzept für die Sicherheit von Netz- und Informationssystemen (Artikel 21 Absatz 2 Buchstabe a der Richtlinie (EU) 2022/2555)****1.1. Konzept für die Sicherheit von Netz- und Informationssystemen****1.1.1. Für die Zwecke von Artikel 21 Absatz 2 Buchstabe a der Richtlinie (EU) 2022/2555 muss das Konzept für die Sicherheit von Netz- und Informationssystemen**

- a) den Ansatz der betreffenden Einrichtungen für das Management der Sicherheit ihrer Netz- und Informationssysteme darlegen;
- b) für die Geschäftsstrategie und die Ziele der betreffenden Einrichtungen geeignet sein und diese ergänzen;
- c) die Ziele der Sicherheit von Netz- und Informationssystemen darlegen;
- d) eine Verpflichtung zur kontinuierlichen Verbesserung der Sicherheit von Netz- und Informationssystemen enthalten;
- e) eine Verpflichtung enthalten, die für seine Umsetzung erforderlichen angemessenen Ressourcen bereitzustellen, einschließlich des erforderlichen Personals, der erforderlichen Finanzmittel sowie der Verfahren, Instrumente und Technologien;
- f) den einschlägigen Mitarbeitenden und interessierten externen Beteiligten mitgeteilt und von ihnen anerkannt werden;
- g) die Festlegung der Rollen und Verantwortlichkeiten gemäß Nummer 1.2 enthalten;
- h) die aufzubewahrenden Unterlagen und die Dauer ihrer Aufbewahrung aufführen;
- i) die themenspezifischen Konzepte aufführen;
- j) Indikatoren und Maßnahmen zur Überwachung seiner Umsetzung und des aktuellen Reifegrads der Netz- und Informationssicherheit in den betreffenden Einrichtungen festlegen;
- k) das Datum der förmlichen Genehmigung durch die Leitungsorgane der betreffenden Einrichtungen (im Folgenden „Leitungsorgane“) enthalten.

1.1.2. Das Konzept für die Sicherheit von Netz- und Informationssystemen wird von den Leitungsorganen mindestens jährlich sowie bei erheblichen Sicherheitsvorfällen oder wesentlichen Änderungen der Betriebsabläufe oder der Risiken überprüft und – soweit angemessen – aktualisiert. Das Ergebnis der Überprüfung wird dokumentiert.**1.2. Rollen, Verantwortlichkeiten und Weisungsbefugnisse****1.2.1. Im Rahmen ihres Konzepts für die Sicherheit von Netz- und Informationssystemen gemäß Nummer 1.1 legen die betreffenden Einrichtungen Verantwortlichkeiten und Weisungsbefugnisse für die Sicherheit von Netz- und Informationssystemen fest und ordnen sie den Rollen zu, weisen sie entsprechend dem Bedarf der jeweiligen Einrichtungen zu und teilen dies den Leitungsorganen mit.****1.2.2. Die betreffenden Einrichtungen verlangen von allen Mitarbeitenden und Dritten, die Netz- und Informationssystem-sicherheit entsprechend dem festgelegten Konzept für die Sicherheit von Netz- und Informationssystemen, den themenspezifischen Konzepten und den Verfahren der betreffenden Einrichtungen anzuwenden.****1.2.3. Mindestens eine Person muss gegenüber den Leitungsorganen direkt für Fragen der Sicherheit von Netz- und Informationssystemen verantwortlich sein.****1.2.4. Je nach Größe der betreffenden Einrichtungen wird die Sicherheit von Netz- und Informationssystemen durch spezielle Rollen oder Aufgaben abgedeckt, die zusätzlich zu den bestehenden Rollen übernommen werden.**

1.2.5. Widerstrebende Pflichten und sich widersprechende Verantwortlichkeiten werden – soweit anwendbar – getrennt.

1.2.6. Die Rollen, Verantwortlichkeiten und Weisungsbefugnisse werden von den Leitungsorganen in geplanten Zeitabständen sowie bei erheblichen Sicherheitsvorfällen oder wesentlichen Änderungen der Betriebsabläufe oder der Risiken überprüft und – soweit angemessen – aktualisiert.

2. **Konzept für das Risikomanagement (Artikel 21 Absatz 2 Buchstabe a der Richtlinie (EU) 2022/2555)**

2.1. *Risikomanagementrahmen*

2.1.1. Für die Zwecke von Artikel 21 Absatz 2 Buchstabe a der Richtlinie (EU) 2022/2555 führen die betreffenden Einrichtungen einen geeigneten Risikomanagementrahmen ein, um die Risiken für die Sicherheit von Netz- und Informationssystemen zu ermitteln und anzugehen, und erhalten diesen Rahmen aufrecht. Die betreffenden Einrichtungen führen Risikobewertungen durch und dokumentieren diese; auf der Grundlage der Ergebnisse erstellen sie einen Risikobehandlungsplan, setzen diesen um und überwachen ihn. Die Ergebnisse der Risikobewertung und die Restrisiken werden von den Leitungsorganen oder – soweit anwendbar – von Personen akzeptiert, die für das Risikomanagement rechenschaftspflichtig und befugt sind, sofern die betreffenden Einrichtungen für eine angemessene Berichterstattung an die Leitungsorgane sorgen.

2.1.2. Für die Zwecke von Nummer 2.1.1 legen die betreffenden Einrichtungen Verfahren für die Ermittlung, Analyse, Bewertung und Behandlung von Risiken fest („Risikomanagementverfahren im Bereich der Cybersicherheit“). Das Risikomanagementverfahren im Bereich der Cybersicherheit ist – soweit anwendbar – fester Bestandteil des gesamten Risikomanagementverfahrens der betreffenden Einrichtungen. Als Teil des Risikomanagementverfahrens im Bereich der Cybersicherheit müssen die betreffenden Einrichtungen

- a) eine Risikomanagementmethodik befolgen;
- b) eine Risikotoleranzschwelle im Einklang mit der Risikobereitschaft der betreffenden Einrichtungen festlegen;
- c) einschlägige Risikokriterien einführen und pflegen;
- d) im Einklang mit einem gefahrenübergreifenden Ansatz die bestehenden Risiken für die Sicherheit von Netz- und Informationssystemen ermitteln und dokumentieren, insbesondere in Bezug auf Dritte sowie auf Risiken, die zu Störungen der Verfügbarkeit, Integrität, Authentizität oder Vertraulichkeit der Netz- und Informationssysteme führen könnten, wobei auch punktuelle Ausfälle zu ermitteln sind;
- e) die bestehenden Risiken für die Sicherheit von Netz- und Informationssystemen analysieren, einschließlich des Niveaus der Bedrohung, der Wahrscheinlichkeit, der Auswirkung und des Risikos unter Berücksichtigung der Erkenntnisse über Cyberbedrohungen und Schwachstellen;
- f) die ermittelten Risiken auf der Grundlage der Risikokriterien bewerten;
- g) geeignete Optionen und Maßnahmen für die Behandlung von Risiken bestimmen;
- h) die Umsetzung der Maßnahmen für die Behandlung von Risiken fortlaufend überwachen;
- i) ermitteln, wer für die Umsetzung der Maßnahmen für die Behandlung von Risiken verantwortlich ist und wann diese erfolgen sollte;
- j) die gewählten Maßnahmen für die Behandlung von Risiken in einem Risikobehandlungsplan dokumentieren und die Gründe für das Eingehen der Restrisiken umfassend erläutern.

2.1.3. Bei der Ermittlung und Priorisierung geeigneter Risikomanagementoptionen und -maßnahmen berücksichtigen die betreffenden Einrichtungen die Ergebnisse der Risikobewertung, die Ergebnisse des Verfahrens zur Bewertung der Wirksamkeit von Risikomanagementmaßnahmen im Bereich der Cybersicherheit, die Umsetzungskosten im Verhältnis zum erwarteten Nutzen, die in Nummer 12.1 genannte Klassifizierung von Anlagen und Werten und die in Nummer 4.1.3 genannte Analyse der betrieblichen Auswirkungen.

2.1.4. Die betreffenden Einrichtungen bewerten die Ergebnisse der Risikobewertung und den Risikobehandlungsplan in geplanten Zeitabständen und mindestens jährlich sowie bei wesentlichen Änderungen der Betriebsabläufe oder der Risiken oder bei erheblichen Sicherheitsvorfällen und aktualisieren sie – soweit angemessen.

2.2. Überwachung der Einhaltung

- 2.2.1. Die betreffenden Einrichtungen überprüfen regelmäßig die Einhaltung ihrer Konzepte für die Sicherheit von Netz- und Informationssystemen, themenspezifischen Konzepten, Vorschriften und Normen. Die Leitungsorgane werden durch regelmäßige Berichterstattung auf der Grundlage der Überprüfungen der Einhaltung über den Stand der Netz- und Informationssicherheit unterrichtet.
- 2.2.2. Die betreffenden Einrichtungen führen ein wirksames System für die Berichterstattung über die Einhaltung der Bestimmungen ein, das ihren Strukturen, Betriebsumfeldern und Bedrohungslandschaften angemessen ist. Das System für die Berichterstattung über die Einhaltung muss den Leitungsorganen einen fundierten Überblick über den aktuellen Stand des Risikomanagements der betreffenden Einrichtungen geben können.
- 2.2.3. Die betreffenden Einrichtungen führen in geplanten Zeitabständen sowie bei erheblichen Sicherheitsvorfällen oder wesentlichen Änderungen der Betriebsabläufe oder der Risiken Maßnahmen zur Überwachung der Einhaltung durch.

2.3. Unabhängige Überprüfung der Netz- und Informationssicherheit

- 2.3.1. Die betreffenden Einrichtungen überprüfen unabhängig ihren Ansatz für das Management der Sicherheit von Netz- und Informationssystemen und dessen Umsetzung, einschließlich Personen, Verfahren und Technologien.
- 2.3.2. Die betreffenden Einrichtungen entwickeln Verfahren zur Durchführung unabhängiger Überprüfungen durch Personen mit angemessener Prüfungskompetenz und pflegen diese Verfahren. Wird die unabhängige Überprüfung von Mitgliedern des Personals der betreffenden Einrichtung durchgeführt, so dürfen die Personen, die die Überprüfungen durchführen, nicht dem Personal des zu überprüfenden Bereichs unterstellt sein. Lässt die Größe der betreffenden Einrichtungen eine solche Trennung der Befugnisse nicht zu, so ergreifen die betreffenden Einrichtungen alternative Maßnahmen, um die Unparteilichkeit der Überprüfungen zu gewährleisten.
- 2.3.3. Die Ergebnisse der unabhängigen Überprüfungen, einschließlich der Ergebnisse der Überwachung der Einhaltung gemäß Nummer 2.2 und der Überwachung und Messung gemäß Nummer 7, werden den Leitungsorganen gemeldet. Gemäß den Risikoakzeptanzkriterien der betreffenden Einrichtungen sind Korrekturmaßnahmen zu ergreifen oder Restrisiken zu akzeptieren.
- 2.3.4. Die unabhängigen Überprüfungen finden in geplanten Zeitabständen sowie bei erheblichen Sicherheitsvorfällen oder wesentlichen Änderungen der Betriebsabläufe oder der Risiken statt.

3. Bewältigung von Sicherheitsvorfällen (Artikel 21 Absatz 2 Buchstabe b der Richtlinie (EU) 2022/2555)

3.1. Konzept für die Bewältigung von Sicherheitsvorfällen

- 3.1.1. Für die Zwecke von Artikel 21 Absatz 2 Buchstabe b der Richtlinie (EU) 2022/2555 arbeiten die betreffenden Einrichtungen ein Konzept für die Bewältigung von Sicherheitsvorfällen aus, in dem Rollen, Verantwortlichkeiten und Verfahren für die zeitnahe Erkennung, Analyse, Eindämmung oder Reaktion, die Wiederherstellung sowie Dokumentation und Meldung in Bezug auf Sicherheitsvorfälle festgelegt werden, und setzen dieses um.
- 3.1.2. Das in Nummer 3.1.1 genannte Konzept muss mit dem Notfallplan für die Aufrechterhaltung und Wiederherstellung des Betriebs gemäß Nummer 4.1 im Einklang stehen. Das Konzept umfasst
 - a) ein Kategorisierungssystem für Sicherheitsvorfälle, das mit der Bewertung und Klassifizierung von Ereignissen gemäß Nummer 3.4.1 im Einklang steht;
 - b) wirksame Kommunikationspläne, auch für die Eskalation und Meldung;
 - c) eine Zuweisung der Rollen bei der Erkennung von Sicherheitsvorfällen und der angemessenen Reaktion darauf an kompetente Mitarbeitende;
 - d) Dokumente, die im Laufe der Erkennung von Sicherheitsvorfällen und der Reaktion darauf zu verwenden sind, wie Anleitungen für die Reaktion bei Sicherheitsvorfällen, Eskalationsschemata, Kontaktlisten und Vorlagen.
- 3.1.3. Die in dem Konzept festgelegten Rollen, Verantwortlichkeiten und Verfahren werden in geplanten Zeitabständen sowie bei erheblichen Sicherheitsvorfällen oder wesentlichen Änderungen der Betriebsabläufe oder der Risiken getestet, überprüft und – soweit angemessen – aktualisiert.

3.2. Überwachung und Protokollierung

- 3.2.1. Die betreffenden Einrichtungen legen Verfahren fest und verwenden Instrumente, um Aktivitäten in ihrem Netz- und Informationssystem zu überwachen und zu protokollieren, damit sie Ereignisse, die als Sicherheitsvorfälle betrachtet werden könnten, erkennen und zur Eindämmung der Auswirkungen entsprechend darauf reagieren können.
- 3.2.2. Soweit durchführbar, erfolgt die Überwachung automatisch und wird vorbehaltlich der betrieblichen Kapazitäten entweder kontinuierlich oder in regelmäßigen Zeitabständen durchgeführt. Die betreffenden Einrichtungen führen ihre Überwachungstätigkeiten so durch, dass es zu möglichst wenigen falsch positiven und falsch negativen Ergebnissen kommt.
- 3.2.3. Auf der Grundlage der in Nummer 3.2.1 genannten Verfahren führen, dokumentieren und überprüfen die betreffenden Einrichtungen Protokolle. Die betreffenden Einrichtungen erstellen auf der Grundlage der Ergebnisse der gemäß Nummer 2.1 durchgeführten Risikobewertung eine Liste der Anlagen und Werte, die Gegenstand der Protokollierung sind. Soweit angemessen, müssen die Protokolle Folgendes enthalten:
- a) relevanten ausgehenden und eingehenden Netzverkehr;
 - b) Einrichtung, Änderung oder Löschung von Nutzern der Netz- und Informationssysteme der betreffenden Einrichtungen und Erweiterung der Berechtigungen;
 - c) Zugriffe auf Systeme und Anwendungen;
 - d) authentifizierungsbezogene Ereignisse;
 - e) alle privilegierten Zugriffe auf Systeme und Anwendungen sowie Aktivitäten der Verwaltungskonten;
 - f) Zugriffe auf kritische Konfigurations- und Backup-Sicherungsdateien oder Änderungen dieser Dateien;
 - g) Ereignisprotokolle und Protokolle von Sicherheitstools wie Antivirenprogrammen, Angriffserkennungssystemen oder Firewalls;
 - h) Nutzung der Systemressourcen sowie deren Leistung;
 - i) physischen Zugang zu Betriebsstätten;
 - j) Zugang zu ihren Netzwerkausrüstungen und -geräten und deren Nutzung;
 - k) Aktivierung, Beendigung und Pausieren der verschiedenen Protokolle;
 - l) Ereignisse im Umfeld.
- 3.2.4. Die Protokolle werden regelmäßig auf ungewöhnliche oder unerwünschte Trends überprüft. Soweit angemessen, legen die betreffenden Einrichtungen geeignete Werte für Alarmschwellen fest. Bei Überschreitung der festgelegten Alarmschwellenwerte wird – soweit angemessen – automatisch ein Alarm ausgelöst. Der betreffenden Einrichtungen stellen sicher, dass im Falle eines Alarms zeitnah eine qualifizierte und angemessene Reaktion eingeleitet wird.
- 3.2.5. Die betreffenden Einrichtungen führen und sichern die Protokolle für einen vorab festgelegten Zeitraum und schützen sie vor unbefugten Zugriffen oder Änderungen.
- 3.2.6. Soweit durchführbar, stellen die betreffenden Einrichtungen sicher, alle Systeme zeitlich synchronisiert sind, um Protokolle zwischen den Systemen für die Ereignisbewertung miteinander in Beziehung setzen zu können. Die betreffenden Einrichtungen erstellen und führen eine Liste aller Anlagen und Werten, die protokolliert werden, und stellen sicher, dass für die Überwachung und Protokollierung Redundanzsysteme zur Verfügung stehen. Die Verfügbarkeit der Überwachungs- und Protokollierungssysteme wird unabhängig von den von ihnen überwachten Systemen überwacht.
- 3.2.7. Die Verfahren sowie die Liste der protokollierten Anlagen und Werte werden in regelmäßigen Abständen und nach erheblichen Sicherheitsvorfällen überprüft und – soweit angemessen – aktualisiert.

3.3. Meldung von Ereignissen

- 3.3.1. Die betreffenden Einrichtungen richten einen einfachen Mechanismus ein, über den ihre Mitarbeitenden, Anbieter und Kunden verdächtige Ereignisse melden können.

3.3.2. Die betreffenden Einrichtungen unterrichten – soweit angemessen – ihre Anbieter und Kunden über den Mechanismus für die Meldung von Ereignissen und schulen ihre Mitarbeitenden regelmäßig in Bezug auf dessen Nutzung.

3.4. *Bewertung und Klassifizierung von Ereignissen*

3.4.1. Die betreffenden Einrichtungen bewerten verdächtige Ereignisse, um festzustellen, ob es sich um Sicherheitsvorfälle handelt, und – falls dies der Fall ist – um deren Art und Schwere zu bestimmen.

3.4.2. Für die Zwecke von Nummer 3.4.1 gehen die betreffenden Einrichtungen wie folgt vor:

- a) Sie führen die Bewertung auf der Grundlage vorab festgelegter Kriterien und einer Triage durch, um die Priorisierung der Eindämmung und Beseitigung von Sicherheitsvorfällen zu bestimmen,
- b) sie bewerten vierteljährlich, ob wiederholte Sicherheitsvorfälle gemäß Artikel 4 dieser Verordnung vorliegen,
- c) sie überprüfen die betreffenden Protokolle für die Zwecke der Bewertung und Klassifizierung von Ereignissen,
- d) sie führen ein Verfahren für die Korrelation und Analyse von Protokollen ein, und
- e) sie bewerten und klassifizieren Ereignisse neu, falls neue Informationen verfügbar werden, oder nach der Auswertung zuvor verfügbarer Informationen.

3.5. *Reaktion auf Sicherheitsvorfälle*

3.5.1. Die betreffenden Einrichtungen reagieren auf Sicherheitsvorfälle zeitnah gemäß dokumentierten Verfahren.

3.5.2. Die Verfahren für Reaktionsmaßnahmen bei Sicherheitsvorfällen umfassen folgende Phasen:

- a) Eindämmung des Sicherheitsvorfalls, um zu verhindern, dass sich dessen Folgen ausbreiten;
- b) Beseitigung, um zu verhindern, dass der Sicherheitsvorfall andauert oder erneut auftritt;
- c) erforderlichenfalls Wiederherstellung nach dem Sicherheitsvorfall.

3.5.3. Die betreffenden Einrichtungen erstellen Pläne und Verfahren für die Kommunikation

- a) mit den Computer-Notfallteams (CSIRTs) oder – soweit anwendbar – mit den zuständigen Behörden im Zusammenhang mit der Meldung von Sicherheitsvorfällen;
- b) zwischen den Mitgliedern des Personals der betreffenden Einrichtung und mit einschlägigen Interessenträgern außerhalb der betreffenden Einrichtung.

3.5.4. Die betreffenden Einrichtungen protokollieren die Tätigkeiten zur Reaktion auf Sicherheitsvorfälle gemäß den in Nummer 3.2.1 genannten Verfahren und sammeln Nachweise.

3.5.5. Die betreffenden Einrichtungen testen ihre Verfahren zur Reaktion auf Sicherheitsvorfälle in geplanten Zeitabständen.

3.6. *Überprüfungen nach Sicherheitsvorfällen*

3.6.1. Nach Sicherheitsvorfällen führen die betreffenden Einrichtungen im Anschluss an die Wiederherstellung – soweit angemessen – nachträgliche Überprüfungen durch. Bei der Überprüfung nach einem Sicherheitsvorfall wird, soweit möglich, die Ursache des Vorfalls ermittelt und es werden die daraus gezogenen Lehren dokumentiert, um das Auftreten und die Folgen künftiger Vorfälle zu verringern.

3.6.2. Die betreffenden Einrichtungen stellen sicher, dass die Überprüfungen nach Sicherheitsvorfällen zur Verbesserung ihres Konzepts für die Netz- und Informationssicherheit, zu Risikobehandlungsmaßnahmen und Verfahren zur Bewältigung und Erkennung von Sicherheitsvorfällen sowie zur Reaktion darauf beitragen.

3.6.3. Die betreffenden Einrichtungen überprüfen in geplanten Zeitabständen, ob Sicherheitsvorfälle entsprechende Überprüfungen nach sich ziehen.

4. **Betriebskontinuitäts- und Krisenmanagement (Artikel 21 Absatz 2 Buchstabe c der Richtlinie (EU) 2022/2555)**

4.1. *Notfallplan für die Aufrechterhaltung und Wiederherstellung des Betriebs*

4.1.1. Für die Zwecke von Artikel 21 Absatz 2 Buchstabe c der Richtlinie (EU) 2022/2555 legen die betreffenden Einrichtungen einen Notfallplan für die Aufrechterhaltung und Wiederherstellung des Betriebs fest, der bei Sicherheitsvorfällen Anwendung findet.

4.1.2. Die Abläufe der betreffenden Einrichtungen werden gemäß dem Notfallplan für die Aufrechterhaltung und Wiederherstellung des Betriebs wiederhergestellt. Der Plan beruht auf den Ergebnissen der gemäß Nummer 2.1 durchgeführten Risikobewertung ein und umfasst – soweit angemessen – Folgendes:

- a) Zweck, Umfang und Zielgruppe;
- b) Rollen und Verantwortlichkeiten;
- c) wichtige Kontaktangaben und (interne und externe) Kommunikationskanäle;
- d) Bedingungen für die Aktivierung und die Deaktivierung des Plans;
- e) Reihenfolge der Wiederherstellung der Betriebsabläufe;
- f) Wiederherstellungspläne für bestimmte Betriebsabläufe, einschließlich der Wiederherstellungsziele;
- g) erforderliche Ressourcen, einschließlich Sicherungen und Redundanzen;
- h) Wiederherstellung und Wiederaufnahme der Tätigkeiten nach vorübergehenden Maßnahmen.

4.1.3. Die betreffenden Einrichtungen führen eine Analyse der betrieblichen Auswirkungen durch, um die möglichen Auswirkungen schwerwiegender Störungen auf ihre Betriebsabläufe zu bewerten, und legen auf der Grundlage der Ergebnisse Kontinuitätsanforderungen für die Netz- und Informationssysteme fest.

4.1.4. Der Notfallplan für die Aufrechterhaltung und Wiederherstellung des Betriebs wird in geplanten Zeitabständen sowie bei erheblichen Sicherheitsvorfällen oder wesentlichen Änderungen der Betriebsabläufe oder der Risiken getestet, überprüft und – soweit angemessen – aktualisiert. Die betreffenden Einrichtungen stellen sicher, dass die aus diesen Tests gezogenen Lehren in die Pläne einfließen.

4.2. *Backup-Sicherungs- und Redundanzmanagement*

4.2.1. Die betreffenden Einrichtungen machen Sicherungskopien der Daten und stellen ausreichend verfügbare Ressourcen, einschließlich Betriebsstätten, Netz- und Informationssysteme sowie Personal, bereit, um ein angemessenes Maß an Redundanz zu gewährleisten.

4.2.2. Auf der Grundlage der Ergebnisse der gemäß Nummer 2.1 durchgeführten Risikobewertung und des Betriebskontinuitätsplans legen die betreffenden Einrichtungen Sicherungspläne fest, die Folgendes umfassen:

- a) Wiederherstellungszeiten;
- b) Gewährleistung, dass Sicherungskopien vollständig und genau sind, einschließlich Konfigurationsdaten und Daten, die in der Umgebung von Cloud-Computing-Diensten gespeichert sind;
- c) Speicherung von Sicherungskopien (online oder offline) an einem oder mehreren sicheren Orten, die sich nicht im selben Netz wie das System sowie in ausreichend großer Entfernung befinden, um Schäden durch einen Notfall am Hauptstandort zu vermeiden;
- d) geeignete physische und logische Zugangskontrollen zu Sicherungskopien entsprechend der Klassifizierungsstufe der Anlagen und Werte;
- e) Wiederherstellung von Daten aus Sicherungskopien;
- f) Aufbewahrungsfristen entsprechend geschäftlichen und regulatorischen Anforderungen.

4.2.3. Die betreffenden Einrichtungen führen regelmäßige Integritätsprüfungen der Sicherungskopien durch.

4.2.4. Auf der Grundlage der Ergebnisse der gemäß Nummer 2.1 durchgeführten Risikobewertung und des Betriebskontinuitätsplans sorgen die betreffenden Einrichtungen für eine ausreichende Verfügbarkeit von Ressourcen durch eine zumindest teilweise Redundanz der folgenden Elemente:

- a) Netz- und Informationssysteme;
- b) Anlagen und Werte, einschließlich Betriebsstätten, Ausrüstung und Verbrauchsmaterial;
- c) Personal mit der erforderlichen Verantwortlichkeit, Weisungsbefugnis und Kompetenz;
- d) geeignete Kommunikationskanäle.

4.2.5. Die betreffenden Einrichtungen stellen – soweit angemessen – sicher, dass sich die Überwachung und Anpassung der Ressourcen, einschließlich Betriebsstätten, Systeme und Personal, ordnungsgemäß auf die Anforderungen an die Sicherung und Redundanz stützen.

4.2.6. Die betreffenden Einrichtungen führen regelmäßige Tests der Wiederherstellung von Sicherungskopien und Redundanzen durch, um sicherzustellen, dass sie bei der Wiederherstellung zuverlässig sind und alle Kopien, Verfahren und Kenntnisse abdecken, die nötig sind, um eine wirksame Wiederherstellung durchzuführen. Die betreffenden Einrichtungen dokumentieren die Testergebnisse und ergreifen erforderlichenfalls Korrekturmaßnahmen.

4.3. *Krisenmanagement*

4.3.1. Die betreffenden Einrichtungen legen ein Verfahren für das Krisenmanagement fest.

4.3.2. Sie sorgen dafür, dass das Krisenmanagementverfahren mindestens die folgenden Elemente abdeckt:

- a) Rollen und Verantwortlichkeiten des Personals und – soweit angemessen – der Anbieter und Diensteanbieter, wobei die Zuweisung der Rollen in Krisensituationen, einschließlich spezifischer zu befolgender Schritte, festgelegt wird;
- b) geeignete Kommunikationsmittel zwischen den betreffenden Einrichtungen und den jeweils zuständigen Behörden;
- c) Anwendung angemessener Maßnahmen zur Gewährleistung der Aufrechterhaltung der Sicherheit von Netz- und Informationssystemen in Krisensituationen.

Für die Zwecke von Buchstabe b umfasst der Informationsfluss zwischen den betreffenden Einrichtungen und den jeweils zuständigen Behörden sowohl obligatorische Mitteilungen wie Meldungen von Sicherheitsvorfällen und entsprechende Fristen als auch fakultative Mitteilungen.

4.3.3. Die betreffenden Einrichtungen führen ein Verfahren für die Verwaltung und Nutzung der von den CSIRTs oder – soweit anwendbar – den zuständigen Behörden erhaltenen Informationen über Sicherheitsvorfälle, Schwachstellen, Bedrohungen oder mögliche Risikominderungsmaßnahmen ein.

4.3.4. Die betreffenden Einrichtungen testen den Krisenmanagementplan in geplanten Zeitabständen oder nach erheblichen Sicherheitsvorfällen oder wesentlichen Änderungen der Betriebsabläufe oder der Risiken und aktualisieren ihn – soweit angemessen.

5. **Sicherheit der Lieferkette (Artikel 21 Absatz 2 Buchstabe d der Richtlinie (EU) 2022/2555)**

5.1. *Konzept für die Sicherheit der Lieferkette*

5.1.1. Für die Zwecke von Artikel 21 Absatz 2 Buchstabe d der Richtlinie (EU) 2022/2555 legen die betreffenden Einrichtungen ein Konzept für die Sicherheit der Lieferkette fest, das die Beziehungen zu ihren direkten Anbietern und Diensteanbietern regelt, setzen es um und wenden es an, um die ermittelten Risiken für die Sicherheit von Netz- und Informationssystemen zu mindern. Im Rahmen des Konzepts für die Sicherheit der Lieferkette legen die betreffenden Einrichtungen ihre Rolle in der Lieferkette fest und teilen sie ihren direkten Anbietern und Diensteanbietern mit.

5.1.2. Im Rahmen des in Nummer 5.1.1 genannten Konzepts für die Sicherheit der Lieferkette legen die betreffenden Einrichtungen Kriterien für die Auswahl von Anbietern und Diensteanbietern und die Auftragsvergabe an sie fest. Diese Kriterien umfassen Folgendes:

- a) die Cybersicherheitsverfahren der Anbieter und Diensteanbieter, einschließlich der Sicherheit ihrer Entwicklungsprozesse;
- b) die Fähigkeit der Anbieter und Diensteanbieter, die von den betreffenden Einrichtungen festgelegten Cybersicherheitsspezifikationen zu erfüllen;
- c) die allgemeine Qualität und Resilienz der IKT-Produkte und -Dienste und die darin enthaltenen Risikomanagementmaßnahmen im Bereich der Cybersicherheit, einschließlich der Risiken und der Klassifizierungsstufe der IKT-Produkte und -Dienste;
- d) die Fähigkeit der betreffenden Einrichtungen, ihre Versorgungsquellen zu diversifizieren und – soweit anwendbar – ihre Abhängigkeit von bestimmten Anbietern zu begrenzen.

5.1.3. Bei der Erstellung ihres Konzepts für die Sicherheit der Lieferkette berücksichtigen die betreffenden Einrichtungen – soweit anwendbar – die Ergebnisse koordinierter Sicherheitsrisikobewertungen kritischer Lieferketten gemäß Artikel 22 Absatz 1 der Richtlinie (EU) 2022/2555.

5.1.4. Auf der Grundlage des Konzepts für die Sicherheit der Lieferkette und unter Berücksichtigung der Ergebnisse der gemäß Nummer 2.1 dieses Anhangs durchgeführten Risikobewertung stellen die betreffenden Einrichtungen sicher, dass in ihren Verträgen mit Anbietern und Diensteanbietern – soweit angemessen – im Rahmen von Leistungsvereinbarungen Folgendes festgelegt wird:

- a) Cybersicherheitsanforderungen an die Anbieter oder Diensteanbieter, einschließlich der Anforderungen an die Sicherheit beim Erwerb von IKT-Diensten oder -Produkten gemäß Nummer 6.1;
- b) Sensibilisierungs-, Qualifikations- und Ausbildungsanforderungen sowie – soweit angemessen – Zertifizierungen, die von den Mitarbeitenden der Anbieter oder Diensteanbieter verlangt werden;
- c) Anforderungen an die Zuverlässigkeitsüberprüfungen der Mitarbeitenden der Anbieter und Diensteanbieter;
- d) eine Verpflichtung der Anbieter und Diensteanbieter, den betreffenden Einrichtungen Sicherheitsvorfälle, die ein Risiko für die Sicherheit der Netz- und Informationssysteme dieser Einrichtungen darstellen, unverzüglich zu melden;
- e) das Recht auf Prüfung oder das Recht auf Erhalt von Prüfberichten;
- f) eine Verpflichtung der Anbieter und Diensteanbieter zur Behebung von Schwachstellen, die ein Risiko für die Sicherheit der Netz- und Informationssysteme der betreffenden Einrichtungen darstellen;
- g) Anforderungen an die Unterauftragsvergabe und – sofern die betreffenden Einrichtungen die Vergabe von Unteraufträgen zulassen – Cybersicherheitsanforderungen an Unterauftragnehmer im Einklang mit den unter Buchstabe a genannten Cybersicherheitsanforderungen;
- h) Pflichten der Anbieter und Diensteanbieter bei Vertragskündigung, z. B. Abruf und Entsorgung der Informationen, die die Anbieter und Diensteanbieter in Wahrnehmung ihrer Aufgaben erlangten.

5.1.5. Die betreffenden Einrichtungen berücksichtigen die in den Nummern 5.1.2 und 5.1.3 genannten Elemente im Rahmen des Auswahlverfahrens für neue Anbieter und Diensteanbieter sowie im Rahmen des Vergabeverfahrens gemäß Nummer 6.1.

5.1.6. Die betreffenden Einrichtungen überprüfen das Konzept für die Sicherheit der Lieferkette, überwachen und bewerten Änderungen der Cybersicherheitsverfahren von Anbietern und Diensteanbietern bei wesentlichen Änderungen der Betriebsabläufe oder der Risiken oder bei erheblichen Sicherheitsvorfällen im Zusammenhang mit der Bereitstellung von IKT-Diensten oder mit Auswirkungen auf die Sicherheit der IKT-Produkte von Anbietern und Diensteanbietern und werden erforderlichenfalls im Hinblick auf diese Änderungen tätig.

5.1.7. Für die Zwecke von Nummer 5.1.6 müssen die betreffenden Einrichtungen

- a) die Berichte über die Umsetzung der Leistungsvereinbarungen regelmäßig verfolgen – soweit anwendbar;
- b) Sicherheitsvorfälle im Zusammenhang mit IKT-Produkten und -Dienstleistungen von Anbietern und Diensteanbietern überprüfen;
- c) die Notwendigkeit außerplanmäßiger Überprüfungen prüfen und die Ergebnisse verständlich dokumentieren;
- d) die Risiken, die sich aus Änderungen im Zusammenhang mit IKT-Produkten und -Dienstleistungen von Anbietern und Diensteanbietern ergeben, analysieren und – soweit angemessen – rechtzeitig Risikominderungsmaßnahmen ergreifen.

5.2. *Verzeichnis der Anbieter und Diensteanbieter*

Die betreffenden Einrichtungen führen ein Verzeichnis ihrer direkten Anbieter und Diensteanbieter, das Folgendes umfasst, und halten es auf dem neuesten Stand:

- a) Kontaktstellen für jeden direkten Anbieter und Diensteanbieter;
- b) eine Liste der IKT-Produkte, -Dienstleistungen und -Prozesse, die der direkte Anbieter oder Diensteanbieter für die betreffenden Einrichtungen bereitstellt.

6. **Sicherheitsmaßnahmen bei Erwerb, Entwicklung und Wartung von Netz- und Informationssystemen (Artikel 21 Absatz 2 Buchstabe e der Richtlinie (EU) 2022/2555)**

6.1. *Sicherheitsmaßnahmen beim Erwerb von IKT-Dienstleistungen oder IKT-Produkten*

6.1.1. Für die Zwecke von Artikel 21 Absatz 2 Buchstabe e der Richtlinie (EU) 2022/2555 legen die betreffenden Einrichtungen auf der Grundlage der gemäß Nummer 2.1 durchgeführten Risikobewertung Verfahren für das Management der Risiken fest, die sich aus dem Erwerb von IKT-Dienstleistungen oder -Produkten für Komponenten ergeben, die für die Sicherheit der Netz- und Informationssysteme der betreffenden Einrichtungen unverzichtbar sind, und setzen sie um.

6.1.2. Für die Zwecke von Nummer 6.1.1 umfassen die in Nummer 6.1.1 genannten Verfahren Folgendes:

- a) Sicherheitsanforderungen, die für die zu erwerbenden IKT-Dienstleistungen oder -Produkte gelten;
- b) Anforderungen an Sicherheitsaktualisierungen während der gesamten Lebensdauer der IKT-Dienstleistungen oder -Produkte oder deren Ersatz nach Ablauf des Unterstützungszeitraums;
- c) Informationen zur Beschreibung der Hardware- und Softwarekomponenten, die in den IKT-Dienstleistungen oder -Produkten verwendet werden;
- d) Informationen zur Beschreibung der umgesetzten Cybersicherheitsfunktionen der IKT-Dienstleistungen oder -Produkte und der Konfiguration, die für ihren sicheren Betrieb erforderlich ist;
- e) die Zusicherung, dass die IKT-Dienstleistungen oder -Produkte die Sicherheitsanforderungen gemäß Buchstabe a erfüllen;
- f) Methoden zur Validierung, dass die bereitgestellten IKT-Dienstleistungen oder -Produkte die angegebenen Sicherheitsanforderungen erfüllen, sowie die Dokumentation der Ergebnisse der Validierung.

6.1.3. Die betreffenden Einrichtungen überprüfen die Verfahren in geplanten Zeitabständen sowie bei erheblichen Sicherheitsvorfällen und aktualisieren sie – soweit angemessen.

6.2. *Sicherer Entwicklungszyklus*

6.2.1. Vor der Entwicklung eines Netz- und Informationssystems, einschließlich Software, legen die betreffenden Einrichtungen Vorschriften für die Sicherheit der Entwicklung von Netz- und Informationssystemen fest und wenden diese bei der internen Entwicklung von Netz- und Informationssystemen und bei der Auslagerung der Entwicklung von Netz- und Informationssystemen an. Die Vorschriften gelten für alle Entwicklungsphasen, einschließlich Spezifikation, Konzeption, Entwicklung, Umsetzung und Tests.

6.2.2. Für die Zwecke von Nummer 6.2.1 müssen die betreffenden Einrichtungen

- a) eine Analyse der Sicherheitsanforderungen in der Spezifikations- und Entwurfsphase jedes Entwicklungs- oder Beschaffungsvorhabens vornehmen, das von den betreffenden Einrichtungen oder im Namen dieser Einrichtungen durchgeführt wird;
- b) bei allen Tätigkeiten zur Entwicklung von Informationssystemen bestimmte Grundsätze für den Aufbau sicherer Systeme und für ein sicheres Programmieren wie etwa die Förderung von konzeptintegrierter Cybersicherheit und Null-Vertrauen-Architekturen anwenden;
- c) Sicherheitsanforderungen in Bezug auf Entwicklungsumgebungen festlegen;
- d) Sicherheitstestverfahren im Entwicklungszyklus einführen und umsetzen;
- e) Daten über Sicherheitstests angemessen auswählen, schützen und verwalten;
- f) die Testdaten entsprechend der Risikobewertung gemäß Nummer 2.1 bereinigen und anonymisieren.

6.2.3. Bei einer ausgelagerten Entwicklung von Netz- und Informationssystemen wenden die betreffenden Einrichtungen darüber hinaus die in den Nummern 5 und 6.1 genannten Grundsätze und Verfahren an.

6.2.4. Die betreffenden Einrichtungen überprüfen ihre Vorschriften für die Sicherheit der Entwicklung in geplanten Zeitabständen und aktualisieren sie erforderlichenfalls.

6.3. *Konfigurationsmanagement*

6.3.1. Die betreffenden Einrichtungen ergreifen geeignete Maßnahmen, um Konfigurationen, einschließlich Sicherheitskonfigurationen von Hardware, Software, Diensten und Netzen, festzulegen, zu dokumentieren, umzusetzen und zu überwachen.

6.3.2. Für die Zwecke von Nummer 6.3.1 müssen die betreffenden Einrichtungen

- a) Konfigurationen für ihre Hardware, Software, Dienste und Netze festlegen und deren Sicherheit gewährleisten;
- b) Verfahren und Instrumente zur Durchsetzung der festgelegten sicheren Konfigurationen für Hardware, Software, Dienste und Netze, für neu installierte Systeme sowie für Systeme, die über ihre gesamte Lebensdauer in Betrieb sind, festlegen und umsetzen.

6.3.3. Die betreffenden Einrichtungen überprüfen die Konfigurationen in geplanten Zeitabständen oder bei erheblichen Sicherheitsvorfällen oder wesentlichen Änderungen der Betriebsabläufe oder der Risiken und aktualisieren sie – soweit angemessen.

6.4. *Änderungsmanagement, Reparatur und Wartung*

6.4.1. Die betreffenden Einrichtungen wenden Verfahren für das Änderungsmanagement an, um Änderungen an Netz- und Informationssystemen zu kontrollieren. Die Verfahren müssen – soweit anwendbar – mit den allgemeinen Grundsätzen der betreffenden Einrichtungen in Bezug auf das Änderungsmanagement im Einklang stehen.

6.4.2. Die in Nummer 6.4.1 genannten Verfahren gelten für Freigaben, Änderungen und Notfalländerungen an in Betrieb befindlicher Software und Hardware sowie für Änderungen der Konfiguration. Durch die Verfahren wird sichergestellt, dass diese Änderungen dokumentiert und auf der Grundlage der gemäß Nummer 2.1 durchgeführten Risikobewertung im Hinblick auf die möglichen Auswirkungen getestet und bewertet werden, bevor sie umgesetzt werden.

6.4.3. Konnten die regulären Änderungsmanagementverfahren aufgrund eines Notfalls nicht befolgt werden, dokumentieren die betreffenden Einrichtungen das Ergebnis der Änderung und die Begründung für die Nichteinhaltung der Verfahren.

6.4.4. Die betreffenden Einrichtungen überprüfen die Verfahren in geplanten Zeitabständen sowie bei erheblichen Sicherheitsvorfällen oder wesentlichen Änderungen der Betriebsabläufe oder der Risiken und aktualisieren sie – soweit angemessen.

6.5. Sicherheitsprüfung

6.5.1. Die betreffenden Einrichtungen legen ein Konzept und Verfahren für Sicherheitsprüfungen fest, setzen sie um und wenden sie an.

6.5.2. Die betreffenden Einrichtungen

- a) legen auf der Grundlage der gemäß Nummer 2.1 durchgeführten Risikobewertung die Notwendigkeit, den Umfang, die Häufigkeit und die Art der Sicherheitsprüfungen fest;
- b) führen Sicherheitsprüfungen nach einer dokumentierten Prüfmethode durch, die sich auf die Komponenten erstrecken, die im Rahmen einer Risikoanalyse als für den sicheren Betrieb relevant eingestuft wurden;
- c) dokumentieren die Art, den Umfang, den Zeitraum und die Ergebnisse der Prüfungen, einschließlich der Bewertung der Kritikalität und der Risikominderungsmaßnahmen für jede Feststellung;
- d) wenden im Falle kritischer Feststellungen Risikominderungsmaßnahmen an.

6.5.3. Die betreffenden Einrichtungen überprüfen ihre Konzepte für die Sicherheitsprüfung in geplanten Zeitabständen und aktualisieren sie – soweit angemessen.

6.6. Sicherheitspatch-Management

6.6.1. Die betreffenden Einrichtungen legen Verfahren, die mit den in Nummer 6.4.1 genannten Änderungsmanagementverfahren im Einklang stehen, und Änderungs-, Schwachstellen- und Risikomanagementverfahren sowie andere einschlägige Verfahren fest und wenden sie an, um sicherzustellen, dass

- a) Sicherheitspatches innerhalb einer angemessenen Frist nach ihrer Verfügbarmachung angewendet werden;
- b) Sicherheitspatches getestet werden, bevor sie in Produktionssystemen angewendet werden;
- c) Sicherheitspatches aus vertrauenswürdigen Quellen stammen und auf ihre Integrität geprüft werden;
- d) zusätzliche Maßnahmen umgesetzt und Restrisiken akzeptiert werden, wenn ein Patch nicht verfügbar ist oder nicht gemäß Nummer 6.6.2 angewendet wird.

6.6.2. Abweichend von Nummer 6.6.1 Buchstabe a können die betreffenden Einrichtungen verzichten, Sicherheitspatches anzuwenden, wenn die Nachteile der Anwendung der Sicherheitspatches die Vorteile für die Cybersicherheit überwiegen. Die betreffenden Einrichtungen dokumentieren und begründen dies ordnungsgemäß.

6.7. Netzsicherheit

6.7.1. Die betreffenden Einrichtungen ergreifen geeignete Maßnahmen, um ihre Netz- und Informationssysteme vor Cyberbedrohungen zu schützen.

6.7.2. Für die Zwecke von Nummer 6.7.1 müssen die betreffenden Einrichtungen

- a) die Architektur des Netzes verständlich und aktuell dokumentieren;
- b) Kontrollen festlegen und durchführen, um die internen Netzdomänen der betreffenden Einrichtungen vor unbefugtem Zugriff zu schützen;
- c) die Kontrollen so konfigurieren, dass Zugriffe und Netzkommunikation verhindert werden, wenn dies für den Betrieb der betreffenden Einrichtungen nicht erforderlich ist;
- d) die Kontrollen für den Fernzugriff auf Netz- und Informationssysteme, einschließlich des Zugangs von Diensteanbietern, festlegen und durchführen;
- e) keine Systeme verwenden, die für die Verwaltung der Umsetzung der Sicherheitskonzepte für andere Zwecke verwendet werden;
- f) nicht benötigte Verbindungen und Dienste ausdrücklich verbieten oder deaktivieren;
- g) – soweit angemessen – den Zugang zu ihren Netz- und Informationssystemen ausschließlich mit von den betreffenden Einrichtungen genehmigten Geräten gewähren;
- h) Verbindungen von Diensteanbietern nur nach einem Genehmigungsantrag und für einen bestimmten Zeitraum, z. B. für die Dauer von Wartungsarbeiten, zulassen;

- i) die Kommunikation zwischen verschiedenen Systemen nur über vertrauenswürdige Kanäle herstellen, die durch logische, kryptografische oder physikalische Trennung von anderen Kommunikationskanälen isoliert sind, und eine sichere Identifizierung ihrer Endpunkte und den Schutz der Kanaldaten vor Änderung oder Offenlegung ermöglichen;
- j) einen Durchführungsplan für den sicheren, angemessenen und schrittweisen vollständigen Übergang zur neuesten Generation der Kommunikationsprotokolle für die Netzwerkschicht annehmen und Maßnahmen zur Beschleunigung dieses Übergangs festlegen;
- k) einen Durchführungsplan für die Einführung international vereinbarter und interoperabler moderner E-Mail-Kommunikationsnormen annehmen, um die E-Mail-Kommunikation zur Minderung von Schwachstellen im Zusammenhang mit E-Mail-Bedrohungen zu sichern, und Maßnahmen zur Beschleunigung dieser Einführung festlegen;
- l) bewährte Verfahren für die Sicherheit des DNS sowie für die Sicherheit und Hygiene des Internet-Routings bei Verkehr, der aus dem Netz stammt und für das Netz bestimmt ist, anwenden.

6.7.3. Die betreffenden Einrichtungen überprüfen diese Maßnahmen in geplanten Zeitabständen sowie bei erheblichen Sicherheitsvorfällen oder wesentlichen Änderungen der Betriebsabläufe oder der Risiken und aktualisieren sie – soweit angemessen.

6.8. Netzsegmentierung

6.8.1. Die betreffenden Einrichtungen segmentieren ihre Systeme entsprechend den Ergebnissen der Risikobewertung gemäß Nummer 2.1 in Netze oder Zonen. Sie segmentieren ihre eigenen Systeme und Netze von Systemen und Netzen Dritter.

6.8.2. Für diese Zwecke müssen die betreffenden Einrichtungen

- a) die funktionale, logische und physische Beziehung, einschließlich des Standorts, zwischen vertrauenswürdigen Systemen und Diensten berücksichtigen;
- b) den Zugang zu einem Netz oder einer Zone auf der Grundlage einer Bewertung seiner/ihrer Sicherheitsanforderungen gewähren;
- c) Systeme, die für den Betrieb der betreffenden Einrichtungen oder für die Sicherheit unverzichtbar sind, in gesicherten Zonen unterbringen;
- d) eine demilitarisierte Zone innerhalb ihrer Kommunikationsnetze aufbauen, um die Sicherheit der Kommunikation, die aus ihren Netzen stammt oder für ihr Netz bestimmt ist, zu gewährleisten;
- e) den Zugang zu und die Kommunikation zwischen und innerhalb von Zonen auf diejenigen beschränken, die für den Betrieb der betreffenden Einrichtungen oder für die Sicherheit erforderlich sind;
- f) das spezielle Netz für die Verwaltung von Netz- und Informationssystemen vom operativen Netz der betreffenden Einrichtungen trennen;
- g) Netzverwaltungskanäle von anderem Netzverkehr trennen;
- h) die Produktionssysteme für die Dienste der betreffenden Einrichtungen von den Systemen trennen, die bei der Entwicklung und beim Testen, einschließlich der Sicherung, verwendet werden.

6.8.3. Die betreffenden Einrichtungen überprüfen die Netzsegmentierung in geplanten Zeitabständen sowie bei erheblichen Sicherheitsvorfällen oder wesentlichen Änderungen der Betriebsabläufe oder der Risiken und aktualisieren sie – soweit angemessen.

6.9. Schutz gegen Schadsoftware und nicht genehmigte Software

6.9.1. Die betreffenden Einrichtungen schützen ihre Netz- und Informationssysteme vor Schadsoftware und nicht genehmigter Software.

6.9.2. Zu diesem Zweck führen die betreffenden Einrichtungen insbesondere Maßnahmen durch, um die Verwendung von Schadsoftware oder nicht genehmigter Software aufzudecken oder zu verhindern. Die betreffenden Einrichtungen stellen – soweit angemessen – sicher, dass ihre Netz- und Informationssysteme mit einer Erkennungs- und Reaktionssoftware ausgestattet sind, die regelmäßig im Einklang mit der gemäß Nummer 2.1 durchgeführten Risikobewertung und den vertraglichen Vereinbarungen mit den Anbietern aktualisiert wird.

6.10. Behandlung und Offenlegung von Schwachstellen

- 6.10.1. Die betreffenden Einrichtungen erlangen Informationen über technische Schwachstellen in ihren Netz- und Informationssystemen, bewerten ihre Exposition gegenüber solchen Schwachstellen und ergreifen geeignete Maßnahmen zum Umgang mit diesen Schwachstellen.
- 6.10.2. Für die Zwecke von Nummer 6.10.1 müssen die betreffenden Einrichtungen
- a) Informationen über Schwachstellen über geeignete Kanäle, wie z. B. Ankündigungen von CSIRTs oder zuständigen Behörden oder von Anbietern oder Diensteanbietern bereitgestellte Informationen, verfolgen;
 - b) – soweit angemessen – Schwachstellen-Scans durchführen und die Ergebnisse der Scans in geplanten Zeitabständen aufzeichnen;
 - c) Schwachstellen, die von den betreffenden Einrichtungen als für ihren Betrieb kritisch eingestuft wurden, unverzüglich beheben;
 - d) sicherstellen, dass die Behandlung von Schwachstellen mit den Verfahren für das Änderungsmanagement, das Sicherheitspatch-Management, das Risikomanagement und das Management von Sicherheitsvorfällen vereinbar ist;
 - e) ein Verfahren für die Offenlegung von Schwachstellen im Einklang mit den geltenden nationalen Konzepten für die koordinierte Offenlegung von Schwachstellen festlegen.
- 6.10.3. Wenn dies wegen der möglichen Auswirkungen der Schwachstelle gerechtfertigt ist, erstellen die betreffenden Einrichtungen einen Plan zur Minderung der Schwachstelle und setzen ihn um. Ansonsten dokumentieren und begründen die betreffenden Einrichtungen, warum die Schwachstelle keine Abhilfemaßnahmen erfordert.
- 6.10.4. Die betreffenden Einrichtungen überprüfen in geplanten Abständen die Kanäle, die sie für die Überwachung von Informationen über Schwachstellen nutzen, und aktualisieren sie – soweit angemessen.

7. **Konzepte und Verfahren zur Bewertung der Wirksamkeit von Risikomanagementmaßnahmen im Bereich der Cybersicherheit (Artikel 21 Absatz 2 Buchstabe f der Richtlinie (EU) 2022/2555)**

- 7.1. Für die Zwecke von Artikel 21 Absatz 2 Buchstabe f der Richtlinie (EU) 2022/2555 legen die betreffenden Einrichtungen ein Konzept und Verfahren fest, setzen sie um und wenden sie an, um zu bewerten, ob die ergriffenen Risikomanagementmaßnahmen im Bereich der Cybersicherheit wirksam umgesetzt und aufrechterhalten werden.
- 7.2. Das in Nummer 7.1 genannte Konzept und die entsprechenden Verfahren tragen den Ergebnissen der Risikobewertung gemäß Nummer 2.1 und früheren erheblichen Sicherheitsvorfällen Rechnung. Die betreffenden Einrichtungen müssen Folgendes bestimmen:
- a) welche Risikomanagementmaßnahmen im Bereich der Cybersicherheit zu überwachen und zu messen sind, einschließlich Verfahren und Kontrollen;
 - b) die Methoden zur Überwachung, Messung, Analyse und Bewertung, sofern zutreffend, um gültige Ergebnisse sicherzustellen;
 - c) wann die Überwachung und Messung durchzuführen ist;
 - d) wer für die Überwachung und die Messung der Wirksamkeit der Risikomanagementmaßnahmen im Bereich der Cybersicherheit zuständig ist;
 - e) wann die Ergebnisse der Überwachung und der Messung zu analysieren und zu bewerten sind;
 - f) wer diese Ergebnisse analysieren und bewerten muss.
- 7.3. Die betreffenden Einrichtungen überprüfen das Konzept und die Verfahren in geplanten Zeitabständen sowie bei erheblichen Sicherheitsvorfällen oder wesentlichen Änderungen der Betriebsabläufe oder der Risiken und aktualisieren sie – soweit angemessen.

8. **Grundlegende Verfahren im Bereich der Cyberhygiene und Schulungen im Bereich der Cybersicherheit (Artikel 21 Absatz 2 Buchstabe g der Richtlinie (EU) 2022/2555)**

8.1. *Sensibilisierungsmaßnahmen und grundlegende Verfahren im Bereich der Cyberhygiene*

8.1.1. Für die Zwecke von Artikel 21 Absatz 2 Buchstabe g der Richtlinie (EU) 2022/2555 stellen die betreffenden Einrichtungen sicher, dass sich ihre Mitarbeitenden, einschließlich der Mitglieder von Leitungsorganen, sowie direkte Anbieter und Diensteanbieter der Risiken bewusst sind, über die Bedeutung der Cybersicherheit informiert werden und Verfahren im Bereich der Cyberhygiene anwenden.

8.1.2. Für die Zwecke von Nummer 8.1.1 bieten die betreffenden Einrichtungen ihren Mitarbeitenden, den Mitgliedern ihrer Leitungsorgane sowie – soweit angemessen – direkten Anbietern und Diensteanbietern gemäß Nummer 5.1.4 ein Sensibilisierungsprogramm an, das

- a) zeitlich so geplant ist, dass die Maßnahmen wiederholt werden und neue Mitarbeitende erreichen;
- b) mit dem Konzept für die Sicherheit von Netz- und Informationssystemen, den themenspezifischen Konzepten und den einschlägigen Verfahren für die Sicherheit von Netz- und Informationssystemen im Einklang steht;
- c) einschlägige Cyberbedrohungen, bestehende Risikomanagementmaßnahmen im Bereich der Cybersicherheit, Kontaktstellen und Ressourcen für zusätzliche Informationen und Beratung zu Cybersicherheitsfragen sowie Verfahren im Bereich der Cyberhygiene für Nutzer abdeckt.

8.1.3. Das Sensibilisierungsprogramm wird – soweit angemessen – in geplanten Zeitabständen im Hinblick auf seine Wirksamkeit getestet. Das Sensibilisierungsprogramm wird in geplanten Zeitabständen aktualisiert und angeboten, wobei Änderungen der Verfahren im Bereich der Cyberhygiene sowie die aktuelle Bedrohungslage und die Risiken für die betreffenden Einrichtungen zu berücksichtigen sind.

8.2. *Sicherheitsschulungen*

8.2.1. Die betreffenden Einrichtungen ermittelt Mitarbeitende, deren Rollen sicherheitsrelevante Fähigkeiten und Fachkenntnisse erfordern, und stellt sicher, dass sie in Bezug auf die Sicherheit von Netz- und Informationssystemen regelmäßig geschult werden.

8.2.2. Die betreffenden Einrichtungen führen ein Schulungsprogramm im Einklang mit dem Konzept für die Sicherheit von Netz- und Informationssystemen, den themenspezifischen Konzepten und anderen einschlägigen Verfahren für die Sicherheit von Netz- und Informationssystemen ein, in dem der Schulungsbedarf für bestimmte Rollen und Positionen auf der Grundlage von Kriterien festgelegt wird, setzen es um und wenden es an.

8.2.3. Die Schulung gemäß Nummer 8.2.1 muss für die Funktion des Mitarbeitenden relevant sein, und ihre Wirksamkeit ist zu bewerten. Die Schulung muss den bestehenden Sicherheitsmaßnahmen Rechnung tragen und Folgendes umfassen:

- a) Anweisungen für die sichere Konfiguration und den sicheren Betrieb der Netz- und Informationssysteme, einschließlich mobiler Geräte;
- b) Unterrichtung über bekannte Cyberbedrohungen;
- c) Schulung in Bezug auf das Verhalten bei sicherheitsrelevanten Ereignissen.

8.2.4. Die betreffenden Einrichtungen führen Schulungen für Mitglieder des Personals durch, die in neue Positionen oder Rollen wechseln, die sicherheitsrelevante Fähigkeiten und Fachkenntnisse erfordern.

8.2.5. Das Programm wird regelmäßig aktualisiert und durchgeführt, wobei geltende Konzepte und Vorschriften, zugewiesene Rollen und Verantwortlichkeiten sowie bekannte Cyberbedrohungen und technische Entwicklungen berücksichtigt werden.

9. **Kryptografie (Artikel 21 Absatz 2 Buchstabe h der Richtlinie (EU) 2022/2555)**

9.1. Für die Zwecke von Artikel 21 Absatz 2 Buchstabe h der Richtlinie (EU) 2022/2555 legen die betreffenden Einrichtungen ein Konzept und Verfahren in Bezug auf Kryptografie fest, setzen sie um und wenden sie an, um eine angemessene und wirksame Nutzung von Kryptografie sicherzustellen, damit die Vertraulichkeit, Authentizität und Integrität der Daten im Einklang mit der Anlagen- und Wertklassifizierung der betreffenden Einrichtungen und den Ergebnissen der gemäß Nummer 2.1 durchgeführten Risikobewertung geschützt sind.

- 9.2. In dem Konzept und den Verfahren gemäß Nummer 9.1 wird Folgendes festgelegt:
- a) im Einklang mit der Einstufung der Anlagen und Werte der betreffenden Einrichtungen die Art, Stärke und Qualität der kryptografischen Maßnahmen, die zum Schutz der Anlagen und Werte der betreffenden Einrichtungen erforderlich sind, einschließlich der Daten, die gespeichert sind oder gerade übermittelt werden;
 - b) die auf der Grundlage von Buchstabe a anzunehmenden Protokolle oder Protokollfamilien sowie kryptografische Algorithmen, Kryptierungsstärke, kryptografische Lösungen und Nutzungsverfahren, die zu genehmigen und für die Verwendung in den betreffenden Einrichtungen erforderlich sind, – soweit angemessen – nach einem Krypto-Agilitätsansatz;
 - c) der Ansatz der betreffenden Einrichtungen in Bezug auf das Schlüsselmanagement, – soweit angemessen – einschließlich der Methoden für
 - i) die Generierung verschiedener Schlüssel für kryptografische Systeme und Anwendungen;
 - ii) die Ausstellung und Erlangung von Public-Key-Zertifikaten;
 - iii) die Verteilung von Schlüsseln an die vorgesehenen Einrichtungen, einschließlich wie der Schlüssel nach Erhalt zu aktivieren ist;
 - iv) die Speicherung von Schlüsseln, einschließlich wie autorisierte Nutzer Zugang zu Schlüsseln erhalten;
 - v) die Änderung oder Aktualisierung von Schlüsseln, einschließlich Vorschriften darüber, wann und wie Schlüssel geändert werden können;
 - vi) den Umgang mit beeinträchtigten Schlüsseln;
 - vii) den Widerruf von Schlüsseln, einschließlich wie Schlüssel zurückzuziehen oder zu deaktivieren sind;
 - viii) die Wiederherstellung verlorener oder beschädigter Schlüssel;
 - ix) die Sicherung oder Archivierung von Schlüsseln;
 - x) die Vernichtung von Schlüsseln;
 - xi) die Protokollierung und Prüfung von Managementtätigkeiten im Zusammenhang mit Schlüsseln;
 - xii) die Festlegung von Aktivierungs- und Deaktivierungsfristen für Schlüssel, damit die Schlüssel nur für den angegebenen Zeitraum gemäß den Vorschriften der Organisation für das Schlüsselmanagement verwendet werden können.
- 9.3. Die betreffenden Einrichtungen überprüfen ihr Konzept und ihre Verfahren in geplanten Zeitabständen und aktualisieren sie – soweit angemessen –, wobei sie dem Stand der Technik im Bereich der Kryptografie Rechnung tragen.

10. **Sicherheit des Personals (Artikel 21 Absatz 2 Buchstabe i der Richtlinie (EU) 2022/2555)**

10.1. *Sicherheit des Personals*

- 10.1.1. Für die Zwecke von Artikel 21 Absatz 2 Buchstabe i der Richtlinie (EU) 2022/2555 stellen die betreffenden Einrichtungen sicher, dass ihre Mitarbeitenden und gegebenenfalls ihre direkten Anbieter und Diensteanbieter ihre Verantwortlichkeiten im Bereich der Sicherheit verstehen und sich zu ihrer Einhaltung verpflichten, soweit dies für die angebotenen Dienste und den Arbeitsplatz angemessen ist und mit dem Konzept der betreffenden Einrichtungen für die Sicherheit von Netz- und Informationssystemen im Einklang steht.
- 10.1.2. Die unter Nummer 10.1.1 genannte Anforderung umfasst Folgendes:
- a) Mechanismen, mit denen sichergestellt wird, dass alle Mitarbeitenden, direkten Anbieter und Diensteanbieter gegebenenfalls die von den betreffenden Einrichtungen gemäß Nummer 8.1 angewandten Standardverfahren im Bereich der Cyberhygiene verstehen und befolgen;
 - b) Mechanismen, mit denen sichergestellt wird, dass sich alle Nutzer mit administrativem oder privilegiertem Zugang ihrer Rollen, Verantwortlichkeiten und Weisungsbefugnisse bewusst sind und entsprechend handeln;
 - c) Mechanismen, mit denen sichergestellt wird, dass die Mitglieder der Leitungsorgane ihre Rollen, Verantwortlichkeiten und Weisungsbefugnisse in Bezug auf die Sicherheit von Netz- und Informationssystemen verstehen und entsprechend handeln;
 - d) Mechanismen für die Einstellung von Personal, das für die jeweiligen Rollen qualifiziert ist, wie z. B. Überprüfung der Referenzen, Überprüfungsverfahren, Validierung von Zeugnissen oder schriftliche Prüfungen.
- 10.1.3. Die betreffenden Einrichtungen überprüfen die Zuweisung von Personal zu bestimmten Rollen gemäß Nummer 1.2 sowie ihre Mittel für Personal in geplanten Zeitabständen und mindestens einmal jährlich. Sie aktualisieren die Zuweisung der Rollen erforderlichenfalls.

10.2. *Zuverlässigkeitsüberprüfung*

10.2.1. Die betreffenden Einrichtungen stellen – soweit durchführbar – sicher, dass Zuverlässigkeitsüberprüfungen ihrer Mitarbeitenden und – soweit anwendbar – der direkten Anbieter und Diensteanbieter gemäß Nummer 5.1.4 durchgeführt werden, wenn dies für deren Rollen, Verantwortlichkeiten und Weisungsbefugnisse erforderlich ist.

10.2.2. Für die Zwecke von Nummer 10.2.1 müssen die betreffenden Einrichtungen

- a) Kriterien festlegen, in denen aufgeführt ist, welche Rollen, Verantwortlichkeiten und Weisungsbefugnisse nur von Personen wahrgenommen werden dürfen, deren Zuverlässigkeit überprüft wurde;
- b) sicherstellen, dass bei diesen Personen Überprüfungen gemäß Nummer 10.2.1 durchgeführt werden, bevor sie mit der Wahrnehmung dieser Rollen, Verantwortlichkeiten und Weisungsbefugnisse beginnen, wobei die geltenden Gesetze, Vorschriften und ethischen Normen im Verhältnis zu den geschäftlichen Anforderungen, der Klassifizierung der Anlagen und Werte gemäß Nummer 12.1 und den Netz- und Informationssystemen, auf die zugegriffen werden soll, sowie den wahrgenommenen Risiken zu berücksichtigen sind.

10.2.3. Die betreffenden Einrichtungen überprüfen ihr Konzept in geplanten Zeitabständen und aktualisieren es – soweit angemessen.

10.3. *Verfahren zur Beendigung oder Änderung des Beschäftigungsverhältnisses*

10.3.1. Die betreffenden Einrichtungen stellen sicher, dass die Verantwortlichkeiten und Pflichten in Bezug auf die Sicherheit von Netz- und Informationssystemen, die auch nach der Beendigung oder der Änderung des Beschäftigungsverhältnisses ihrer Mitarbeitenden gültig bleiben, vertraglich festgelegt und durchgesetzt werden.

10.3.2. Für die Zwecke von Nummer 10.3.1 nehmen die betreffenden Einrichtungen in die Arbeits- und Beschäftigungsbedingungen, den Vertrag oder die Vereinbarung der betreffenden Person die Verantwortlichkeiten und Pflichten auf, die auch nach Beendigung des Beschäftigungsverhältnisses oder des Vertrags gültig bleiben, wie z. B. Vertraulichkeitsklauseln.

10.4. *Disziplinarverfahren*

10.4.1. Die betreffenden Einrichtungen führen ein Disziplinarverfahren für den Umgang mit Verstößen gegen die Konzepte für die Sicherheit von Netz- und Informationssystemen ein, machen es bekannt und erhalten es aufrecht. In dem Verfahren sind die einschlägigen rechtlichen, gesetzlichen, vertraglichen und geschäftlichen Anforderungen zu berücksichtigen.

10.4.2. Die betreffenden Einrichtungen überprüfen das Disziplinarverfahren in geplanten Zeitabständen sowie – soweit angemessen – bei rechtlichen Änderungen oder bei wesentlichen Änderungen der Betriebsabläufe oder der Risiken und aktualisieren es gegebenenfalls.

11. **Zugriffskontrolle (Artikel 21 Absatz 2 Buchstaben i und j der Richtlinie (EU) 2022/2555)**

11.1. *Konzept für die Zugriffskontrolle*

11.1.1. Für die Zwecke von Artikel 21 Absatz 2 Buchstabe i der Richtlinie (EU) 2022/2555 legen die betreffenden Einrichtungen auf der Grundlage von geschäftlichen Anforderungen sowie Anforderungen an die Sicherheit von Netz- und Informationssystemen Konzepte für die logische und physische Kontrolle des Zugangs zu ihren Netz- und Informationssystemen fest, dokumentieren sie und setzen sie um.

11.1.2. Die in Nummer 11.1.1. genannten Konzepte müssen

- a) für den Zugang von Personen, einschließlich Personal, Besuchern und externen Einrichtungen wie Anbietern und Diensteanbietern, gelten;
- b) für den Zugang von Netz- und Informationssystemen gelten;

- c) sicherstellen, dass der Zugang nur Nutzern gewährt wird, die angemessen authentifiziert wurden.
- 11.1.3. Die betreffenden Einrichtungen überprüfen die Konzepte in geplanten Zeitabständen sowie bei erheblichen Sicherheitsvorfällen oder wesentlichen Änderungen der Betriebsabläufe oder der Risiken und aktualisieren sie – soweit angemessen.
- 11.2. *Management von Zugangs- und Zugriffsrechten*
 - 11.2.1. Die betreffenden Einrichtungen gewähren, ändern, löschen und dokumentieren Zugangs- und Zugriffsrechte für die Netz- und Informationssysteme im Einklang mit dem in Nummer 11.1 genannten Konzept für die Zugriffskontrolle.
 - 11.2.2. Die betreffenden Einrichtungen
 - a) gewähren und entziehen Zugangs- und Zugriffsrechte auf der Grundlage des Grundsatzes „Kenntnis nur, wenn nötig“ (*Need-to-know*), des Grundsatzes der Nutzungsnotwendigkeit (*Need-to-use*) und des Grundsatzes der Aufgabentrennung;
 - b) stellen sicher, dass die Zugangs- und Zugriffsrechte bei Beendigung oder Änderung des Beschäftigungsverhältnisses entsprechend geändert werden;
 - c) stellen sicher, dass der Zugang zu Netz- und Informationssystemen von den einschlägigen Personen genehmigt wird;
 - d) stellen sicher, dass die Zugangs- und Zugriffsrechte dem Zugang bzw. Zugriff Dritter, wie Besucher, Anbieter und Diensteanbieter, angemessen Rechnung tragen, insbesondere durch Beschränkung der Zugangs- und Zugriffsrechte in Bezug auf Umfang und Dauer;
 - e) führen ein Register der gewährten Zugangs- und Zugriffsrechte;
 - f) protokollieren das Management von Zugangs- und Zugriffsrechten.
 - 11.2.3. Die betreffenden Einrichtungen überprüfen die Zugangs- und Zugriffsrechte in geplanten Zeitabständen und ändern sie bei organisatorischen Änderungen. Die betreffenden Einrichtungen dokumentieren die Ergebnisse der Überprüfung, einschließlich der erforderlichen Änderungen der Zugangs- und Zugriffsrechte.
- 11.3. *Privilegierte Konten und Systemverwaltungskonten*
 - 11.3.1. Die betreffenden Einrichtungen halten sich an Grundsätze für das Management von privilegierten Konten und Systemverwaltungskonten als Teil des in Nummer 11.1 genannten Konzepts für die Zugriffskontrolle.
 - 11.3.2. Mit den in Nummer 11.3.1 genannten Konzepten
 - a) müssen starke Verfahren zur Identifizierung, Authentifizierung (z. B. Multifaktor-Authentifizierung) und Genehmigung für privilegierte Konten und Systemverwaltungskonten eingerichtet werden;
 - b) müssen spezielle Konten eingerichtet werden, die ausschließlich für Systemverwaltungsvorgänge, wie Installation, Konfiguration, Verwaltung oder Wartung, zu verwenden sind;
 - c) müssen die Systemverwaltungsrechte so weit wie möglich individuell zugeschnitten und einschränkt werden;
 - d) muss festgelegt werden, dass Systemverwaltungskonten ausschließlich zur Verbindung mit Systemverwaltungssystemen verwendet werden.
 - 11.3.3. Die betreffenden Einrichtungen überprüfen die Zugangs- und Zugriffsrechte für privilegierte Konten und Systemverwaltungskonten in geplanten Zeitabständen, ändern diese bei organisatorischen Änderungen und dokumentieren die Ergebnisse der Überprüfung, einschließlich der erforderlichen Änderungen der Zugriffsrechte.
- 11.4. *Systemverwaltungssysteme*
 - 11.4.1. Die betreffenden Einrichtungen beschränken und kontrollieren die Nutzung von Systemverwaltungskonten im Einklang mit dem in Nummer 11.1 genannten Konzept für die Zugriffskontrolle.
 - 11.4.2. Für diese Zwecke müssen die betreffenden Einrichtungen

- a) Systemverwaltungssysteme ausschließlich für die Zwecke der Systemverwaltung und nicht für andere Vorgänge verwenden;
- b) solche Systeme logisch von Anwendungssoftware, die nicht für Systemverwaltungszwecke verwendet wird, trennen;
- c) den Zugang zu Systemverwaltungssystemen durch Authentifizierung und Verschlüsselung schützen.

11.5. Identifizierung

11.5.1. Die betreffenden Einrichtungen verwalten den gesamten Lebenszyklus der Identitäten (Kennungen) der Netz- und Informationssysteme und ihrer Nutzer.

11.5.2. Für diese Zwecke müssen die betreffenden Einrichtungen

- a) eindeutige Kennungen für die Netz- und Informationssysteme und deren Nutzer einrichten;
- b) die Nutzerkennung mit einer einzigen Person verknüpfen;
- c) die Überwachung der Kennungen der Netz- und Informationssysteme sicherstellen;
- d) das Management von Identitäten (Kennungen) protokollieren.

11.5.3. Die betreffenden Einrichtungen genehmigen Kennungen, die mehreren Personen zugewiesen wurden, wie z. B. gemeinsame Kennungen, nur dann, wenn sie aus geschäftlichen oder operativen Gründen erforderlich sind, einem ausdrücklichen Genehmigungsverfahren unterliegen und dokumentiert werden. Die betreffenden Einrichtungen berücksichtigen Kennungen, die mehreren Personen im Rahmen des in Nummer 2.1 genannten Rahmens für das Risikomanagement im Bereich der Cybersicherheit zugewiesen wurden.

11.5.4. Die betreffenden Einrichtungen überprüfen regelmäßig die Kennungen der Netz- und Informationssysteme und ihrer Nutzer und deaktivieren sie unverzüglich, falls sie nicht mehr benötigt werden.

11.6. Authentifizierung

11.6.1. Die betreffenden Einrichtungen verwenden sichere Authentifizierungsverfahren und -techniken auf der Grundlage von Zugangsbeschränkungen und des Konzepts für die Zugriffskontrolle.

11.6.2. Für diese Zwecke müssen die betreffenden Einrichtungen

- a) sicherstellen, dass die Stärke der Authentifizierung für die Klassifizierung der Anlage bzw. des Werts, auf die zugegriffen werden soll, angemessen ist;
- b) die Verwaltung geheimer Authentifizierungsinformationen und deren Zuweisung an die Nutzer durch ein Verfahren kontrollieren, das die Vertraulichkeit der Informationen gewährleistet, einschließlich Anweisungen an das Personal in Bezug auf den angemessenen Umgang mit Authentifizierungsinformationen;
- c) die Änderung von Authentifizierungsdaten zu Beginn, sodann in vorab festgelegten Zeitabständen und immer dann verlangen, wenn der Verdacht besteht, dass die Authentifizierungsdaten beeinträchtigt wurden;
- d) das Zurücksetzen der Authentifizierungsdaten und die Sperrung von Nutzern nach einer vorab festgelegten Anzahl erfolgloser Anmeldeversuche verlangen;
- e) inaktive Sitzungen nach einem im Voraus festgelegten Zeitraum der Inaktivität beenden und
- f) für den Zugriff auf privilegierte Konten oder Verwaltungskonten gesonderte Authentifizierungsdaten verlangen.

11.6.3. Die betreffenden Einrichtungen verwenden – soweit durchführbar – modernste Authentifizierungsmethoden, die dem damit verbundenen bewerteten Risiko und der Klassifizierung der Anlage bzw. des Werts, auf die zugegriffen werden soll, entsprechen, sowie eindeutige Authentifizierungsinformationen.

11.6.4. Die betreffenden Einrichtungen überprüfen die Authentifizierungsverfahren und -techniken in geplanten Zeitabständen.

11.7. Multifaktor-Authentifizierung

- 11.7.1. Die betreffenden Einrichtungen stellen sicher, dass die Nutzer – soweit angemessen – durch mehrere Authentifizierungsfaktoren oder kontinuierliche Authentifizierungsmechanismen für den Zugang zu den Netz- und Informationssystemen der betreffenden Einrichtungen im Einklang mit der Klassifizierung der Anlage bzw. des Werts, auf die zugegriffen werden soll, authentifiziert werden.
- 11.7.2. Die betreffenden Einrichtungen stellen sicher, dass die Stärke der Authentifizierung für die Klassifizierung der Anlage bzw. des Werts, auf die zugegriffen werden soll, angemessen ist.
12. **Anlagen- und Wertemanagement (Artikel 21 Absatz 2 Buchstabe i der Richtlinie (EU) 2022/2555)**
- 12.1. *Anlagen- und Werteklassifizierung*
- 12.1.1. Für die Zwecke von Artikel 21 Absatz 2 Buchstabe i der Richtlinie (EU) 2022/2555 legen die betreffenden Einrichtungen für alle Anlagen und Werte (einschließlich Informationen), die in den Anwendungsbereich ihrer Netz- und Informationssysteme fallen, Klassifizierungsstufen für das erforderliche Schutzniveau fest.
- 12.1.2. Für die Zwecke von Nummer 12.1.1 müssen die betreffenden Einrichtungen
- a) ein System von Klassifizierungsstufen für Anlagen und Werte festlegen;
 - b) allen Anlagen und Werten eine Klassifizierungsstufe zuordnen, die auf Vertraulichkeits-, Integritäts-, Authentizitäts- und Verfügbarkeitsanforderungen beruht, um den entsprechend ihrer Sensibilität, ihrer Kritikalität, ihres Risikos und ihres Geschäftswerts erforderlichen Schutz anzugeben;
 - c) die Verfügbarkeitsanforderungen in Bezug auf die Anlagen und Werte an die in ihrem Notfallplan für die Aufrechterhaltung und Wiederherstellung des Betriebs festgelegten Ziele für die Bereitstellung und Wiederherstellung anpassen.
- 12.1.3. Die betreffenden Einrichtungen überprüfen regelmäßig die Klassifizierungsstufen der Anlagen und Werte und aktualisieren sie – soweit angemessen.
- 12.2. *Behandlung von Anlagen und Werten*
- 12.2.1. Die betreffenden Einrichtungen legen ein Konzept für die ordnungsgemäße Behandlung von Anlagen und Werten (einschließlich Informationen) im Einklang mit ihrem Konzept für die Sicherheit ihrer Netz- und Informationssysteme fest, setzen es um und wenden es an und teilen dieses Konzept für die ordnungsgemäße Behandlung von Anlagen und Werten allen Personen mit, die Anlagen und Werte nutzen oder damit umgehen.
- 12.2.2. Das Konzept muss
- a) den gesamten Lebenszyklus der Anlagen und Werte abdecken, einschließlich Erwerb, Verwendung, Speicherung, Transport und Entsorgung;
 - b) Vorschriften für die sichere Verwendung, die sichere Speicherung, den sicheren Transport und die unwiederbringliche Löschung und Vernichtung der Anlagen und Werte;
 - c) vorsehen, dass die Übertragung unter Berücksichtigung der Art der zu übertragenden Anlage bzw. des zu übertragenden Werts sicher erfolgt.
- 12.2.3. Die betreffenden Einrichtungen überprüfen das Konzept in geplanten Zeitabständen sowie bei erheblichen Sicherheitsvorfällen oder wesentlichen Änderungen der Betriebsabläufe oder der Risiken und aktualisieren dieses – soweit angemessen.
- 12.3. *Konzept für Wechseldatenträger*
- 12.3.1. Die betreffenden Einrichtungen legen ein Konzept für das Management von Wechseldatenträgern fest, setzen es um und wenden es an und teilen es ihren Mitarbeitenden und Dritten mit, die Wechseldatenträger in den Räumlichkeiten der betreffenden Einrichtungen oder an anderen Orten, an denen die Wechseldatenträger mit den Netz- und Informationssystemen der betreffenden Einrichtungen verbunden sind, benutzen.
- 12.3.2. Das Konzept muss
- a) eine technische Sperrung von Verbindungen mit Wechseldatenträgern vorsehen, es sei denn, es liegen organisatorische Gründe für deren Nutzung vor;

- b) vorsehen, dass die Selbstausführung von Dateien von solchen Datenträgern verhindert wird und die Datenträger auf Schadcodes gescannt werden, bevor sie in den Systemen der betreffenden Einrichtungen verwendet werden können;
- c) Maßnahmen zur Kontrolle und zum Schutz von tragbaren Speichergeräten, die gespeicherte und gerade übermittelte Daten enthalten, vorsehen;
- d) gegebenenfalls Maßnahmen für den Einsatz kryptografischer Verfahren zum Schutz von Daten auf Wechseldatenträgern vorsehen.

12.3.3. Die betreffenden Einrichtungen überprüfen das Konzept in geplanten Zeitabständen sowie bei erheblichen Sicherheitsvorfällen oder wesentlichen Änderungen der Betriebsabläufe oder der Risiken und aktualisieren dieses – soweit angemessen.

12.4. *Anlagen- und Werteinventar*

12.4.1. Die betreffenden Einrichtungen erstellen und pflegen ein vollständiges, genaues, aktuelles und kohärentes Inventar ihrer Anlagen und Werte. Sie erfassen Änderungen der Einträge im Anlagen- und Werteinventar auf nachvollziehbare Weise.

12.4.2. Die Granularität des Anlagen- und Werteinventars liegt auf einem Niveau, dass den Bedürfnissen der betreffenden Einrichtungen entspricht. Das Inventar umfasst Folgendes:

- a) die Liste der Betriebsabläufe und Dienste und ihre Beschreibung,
- b) die Liste der Netz- und Informationssysteme und anderer zugehöriger Anlagen und Werte, die die Abläufe und die Dienste der betreffenden Einrichtungen unterstützen.

12.4.3. Die betreffenden Einrichtungen überprüfen und aktualisieren regelmäßig das Inventar und ihre Anlagen und Werte und dokumentieren den Verlauf der Änderungen.

12.5. *Abgabe, Rückgabe oder Löschung von Anlagen und Werten bei Beendigung des Beschäftigungsverhältnisses*

Die betreffenden Einrichtungen legen Verfahren fest, setzen sie um und wenden sie an, um sicherzustellen, dass ihre Anlagen und Werte, die sich in der Verwahrung des Personals befinden, bei Beendigung des Beschäftigungsverhältnisses abgegeben, zurückgegeben oder gelöscht werden, und dokumentieren die Abgabe, Rückgabe und Löschung dieser Anlagen und Werte. Ist die Abgabe, Rückgabe oder Löschung von Anlagen und Werten nicht möglich, so stellen die betreffenden Einrichtungen sicher, dass die Anlagen und Werte gemäß Nummer 12.2.2 nicht mehr auf die Netz- und Informationssysteme der betreffenden Einrichtungen zugreifen können.

13. **Sicherheit des Umfelds und physische Sicherheit (Artikel 21 Absatz 2 Buchstaben c, e und i der Richtlinie (EU) 2022/2555)**

13.1. *Unterstützende Versorgungsleistungen*

13.1.1. Für die Zwecke von Artikel 21 Absatz 2 Buchstabe c der Richtlinie (EU) 2022/2555 verhindern die betreffenden Einrichtungen Verluste, Schäden oder Beeinträchtigungen von Netz- und Informationssystemen oder Unterbrechungen ihres Betriebs aufgrund des Ausfalls und der Störung unterstützender Versorgungsleistungen.

13.1.2. Für diese Zwecke müssen die betreffenden Einrichtungen – soweit angemessen –

- a) ihre Betriebsstätten vor Stromausfällen und anderen Störungen schützen, die durch Ausfälle bei unterstützenden Versorgungsunternehmen z. B. für Strom, Telekommunikation, Wasser, Gas, Abwasser, Lüftung und Klimatisierung verursacht werden;
- b) die Nutzung von Redundanzsystemen für Versorgungsleistungen in Erwägung ziehen;
- c) Versorgungsleistungen, die Strom und Telekommunikationsdienste für den Transport von Daten oder für den Betrieb von Netz- und Informationssystemen bereitstellen, vor Abhörung und Beschädigung schützen;
- d) die unter Buchstabe c genannten Versorgungsleistungen überwachen und dem zuständigen internen oder externen Personal die Ereignisse melden, die außerhalb der in Nummer 13.2.2 Buchstabe b genannten Mindest- und Höchstkontrollwerteliegen und Auswirkungen auf die Versorgungsleistungen haben;
- e) Verträge über die Notversorgung mit entsprechenden Leistungen abschließen, z. B. für Brennstoff für die Notstromversorgung;

- f) die kontinuierliche Wirksamkeit, Überwachung, Wartung und Erprobung der Netz- und Informationssysteme, die für den Betrieb des angebotenen Dienstes erforderlich sind, gewährleisten, insbesondere Strom, Temperatur- und Feuchtigkeitsregelung, Telekommunikation und Internetverbindung.
- 13.1.3. Die betreffenden Einrichtungen testen die Schutzmaßnahmen in geplanten Zeitabständen oder nach erheblichen Sicherheitsvorfällen oder wesentlichen Änderungen der Betriebsabläufe oder der Risiken und aktualisieren sie – soweit angemessen.
- 13.2. *Schutz vor physischen Bedrohungen und Bedrohungen des Umfelds*
 - 13.2.1. Für die Zwecke von Artikel 21 Absatz 2 Buchstabe e der Richtlinie (EU) 2022/2555 verhindern oder verringern die betreffenden Einrichtungen die Folgen von Ereignissen, die von physischen Bedrohungen und Bedrohungen des Umfelds wie Naturkatastrophen und anderen vorsätzlichen oder unbeabsichtigten Bedrohungen ausgehen, auf der Grundlage der Ergebnisse der gemäß Nummer 2.1 durchgeführten Risikobewertung.
 - 13.2.2. Für diese Zwecke müssen die betreffenden Einrichtungen – soweit angemessen –
 - a) Schutzmaßnahmen gegen physische Bedrohungen und Bedrohungen des Umfelds konzipieren und umsetzen;
 - b) Mindest- und Höchstkontrollwerte für physische Bedrohungen und Bedrohungen des Umfelds bestimmen;
 - c) die Umgebungsparameter überwachen und dem zuständigen internen oder externen Personal Ereignisse melden, die außerhalb der in Buchstabe b genannten Mindest- und Höchstkontrollwerte liegen.
 - 13.2.3. Die betreffenden Einrichtungen testen die Schutzmaßnahmen gegen physische Bedrohungen und Bedrohungen des Umfelds in geplanten Zeitabständen oder nach erheblichen Sicherheitsvorfällen oder wesentlichen Änderungen der Betriebsabläufe oder der Risiken und aktualisieren sie – soweit angemessen.
- 13.3. *Perimeter und physische Zutrittskontrolle*
 - 13.3.1. Für die Zwecke von Artikel 21 Absatz 2 Buchstabe i der Richtlinie (EU) 2022/2555 verhindern und überwachen die betreffenden Einrichtungen unbefugten physischen Zutritt zu, Beschädigungen von und Eingriffe in ihre Netz- und Informationssysteme.
 - 13.3.2. Für diese Zwecke müssen die betreffenden Einrichtungen
 - a) auf der Grundlage der gemäß Nummer 2.1 durchgeführten Risikobewertung Sicherheitsperimeter festlegen und nutzen, um Bereiche zu schützen, in denen sich Netz- und Informationssysteme und andere zugehörige Anlagen befinden;
 - b) die unter Buchstabe a genannten Bereiche durch geeignete Zutrittskontrollen und Zugangspunkte schützen;
 - c) Maßnahmen für die physische Sicherheit von Büros, Räumen und Betriebsstätten konzipieren und umsetzen;
 - d) ihrer Räumlichkeiten kontinuierlich in Bezug auf unbefugten physischen Zutritt überwachen.
 - 13.3.3. Die betreffenden Einrichtungen testen die Maßnahmen zur physischen Zutrittskontrolle in geplanten Zeitabständen oder nach erheblichen Sicherheitsvorfällen oder wesentlichen Änderungen der Betriebsabläufe oder der Risiken und aktualisieren sie – soweit angemessen.